ORDER FOR SUPPLIES OR SERVICES

PAGE 1 OF PAGES 57

IMPORTANT: Mark all packages and papers with contract and/or order numbers.

1. DATE OF ORDER: 03/25/2025	2. CONTRACT NO. *(If any)*
3. ORDER NO.	4. REQUISITION/REFERENCE NO.: 0000HCWD-2026-96318

5. ISSUING OFFICE *(Address correspondence to)*
Centers for Disease Control and Prevention
Chamblee Campus Building 102, MS S102-4
4770 Buford Hwy
Atlanta, GA 30341-3717

7. TO:

a. NAME OF CONTRACTOR

b. COMPANY NAME

c. STREET ADDRESS

d. CITY | e. STATE | f. ZIP CODE –

6. SHIP TO:

a. NAME OF CONSIGNEE: CDC (CGH) Div Glbl Hlth Protection

b. STREET ADDRESS: 1600 Clifton Road, Building 21
9th floor, MS E93

c. CITY: Atlanta, GA | d. STATE: GA | e. ZIP CODE: 30329-4018

f. SHIP VIA

8. TYPE OF ORDER

☐ a. PURCHASE
REFERENCE YOUR:
Please furnish the following on the terms and conditions specified on both sides of this order and on the attached sheet, if any, including delivery as indicated.

☒ b. DELIVERY
Except for billing instructions on the reverse, this delivery order is subject to instructions contained on this side only of this form and is issued subject to the terms and conditions of the above-numbered contract.

9. ACCOUNTING AND APPROPRIATION DATA: 9390NLD 2512 2026 75-2527-0955 5638411101

10. REQUISITIONING OFFICE: HCWD

11. BUSINESS CLASSIFICATION (*Check appropriate box(es)*)
☒ a. SMALL 8(a) ☐ b. OTHER THAN SMALL ☐ c. DISADVANTAGED ☐ d. WOMEN-OWNED

12. F.O.B. POINT	14. GOVERNMENT B/L NO.	15. DELIVER TO F.O.B. POINT ON OR BEFORE *(Date)*	16. DISCOUNT TERMS
Destination		04/14/2030	Net 30 Days

13. PLACE OF: a. INSPECTION | b. ACCEPTANCE

17. SCHEDULE ***(See reverse for Rejections)***

ITEM NO. (a)	SUPPLIES OR SERVICES (b)	QUANTITY ORDERED (c)	UNIT (d)	UNIT PRICE (e)	AMOUNT (f)	QUANTITY ACCEPTED (g)
	The requirement is solicited as a competitive 8(a) award under the ***8(a) STARS III GWAC*** (STARS III) program **Questions Due Date:** 03/26/2026, 2:00 PM EDT(CLOSED) **Proposal Due Date:** 04/9/2026, 2:00 PM EDT Contracting Officer: Debra Baker; xvv9@cdc.gov; 404.498.4855					

18. SHIPPING POINT | 19. GROSS SHIPPING WEIGHT | 20. INVOICE NO.

17(h) TOT. *(Cont.)*

SEE BILLING INSTRUCTIONS ON REVERSE

21. MAIL INVOICE TO:

a. NAME: Centers for Disease Control and Prevention (FMO)

b. STREET ADDRESS *(or P.O. Box)*: PO Box 15580 404-718-8100

c. CITY: Atlanta | d. STATE: GA | e. ZIP CODE: 303330080

17(i) GRAND TOTAL

22. UNITED STATES OF AMERICA *(Signature)* ▶

23. NAME *(Typed)*: Debra A. Baker
TITLE: CONTRACTING/ORDERING OFFICER

SUPPLEMENTAL INVOICING INFORMATION

If desired, this order (or a copy thereof) may be used by the Contractor as the Contractor's invoice, instead of a separate invoice, provided the following statement, (signed and dated) is on (or attached to) the order: "Payment is requested in the amount of $_____. No other invoice will be submitted." However, if the Contractor wishes to submit an invoice, the following information must be provided: contract number (if any), order number, item number(s), description of supplies or service, sizes, quantities, unit prices, and extended totals. Prepaid shipping costs will be indicated as a separate item on the invoice. Where shipping costs exceed $10 (except for parcel post), the billing must be supported by a bill of lading or receipt. When several orders are invoiced to an ordering activity during the same billing period, consolidated periodic billings are encouraged.

RECEIVING REPORT

Quantity in the "Quantity Accepted" column on the face of this order has been ☐ inspected, ☐ accepted, ☐ received by me and conforms to contract. Items listed below have been rejected for the reasons indicated.

SHIPMENT NUMBER	PARTIAL		DATE RECEIVED	SIGNATURE OF AUTHORIZED U.S. GOV'T REP.	DATE
	FINAL				
TOTAL CONTAINERS		GROSS WEIGHT	RECEIVED AT	TITLE	

REPORT OF REJECTIONS

ITEM NO.	SUPPLIES OR SERVICES	UNIT	QUANTITY REJECTED	REASON FOR REJECTION

SECTION B - SUPPLIES OR SERVICES AND PRICES/COSTS

ITEM	SUPPLIES / SERVICES	QTY / UNIT	UNIT PRICE	EXTENDED PRICE
0001	DGHP OD Office 365 Development Support in accordance with the Performance Work Statement • Firm-Fixed Price CLIN • Severable Services Period of Performance: 04/15/2026 – 04/14/2027	12 months	$	$
0002	Travel - Optional Period of Performance:04/15/2026 -04/14/2027	1 Each	$	$ Not to Exceed
0003	Contract Access Fee (CAF)	1 Each	$	$

Option Period 1:

ITEM	SUPPLIES / SERVICES	QTY / UNIT	UNIT PRICE	EXTENDED PRICE
1001	DGHP OD Office 365 Development Support in accordance with the Performance Work Statement • Firm-Fixed Price CLIN • Severable Services Period of Performance 04/15/2027-04/14/2028	12 months	$	$
1002	Travel - Optional - OY1 Period of Performance 04/15/2027-04/14/2028	1 Each	$	$ Not to Exceed
1003	Contract Access Fee (CAF)	1 Each	$	$

Option Period 2:

ITEM	SUPPLIES / SERVICES	QTY / UNIT	UNIT PRICE	EXTENDED PRICE
2001	DGHP OD Office 365 Development Support in accordance with the Performance Work Statement • Firm-Fixed Price CLIN • Severable Services Period of Performance 04/15/2028-04/14/2029	12 months	$	$
2002	Travel - Optional CLIN - Option Year 2 Period of Performance 04/15/2028-04/14/2029	1 Each	$	$ Not to Exceed
2003	Contract Access Fee (CAF)	1 Each	$	$

Option Period 3:

ITEM	SUPPLIES / SERVICES	QTY / UNIT	UNIT PRICE	EXTENDED PRICE
3001	DGHP OD Office 365 Development Support in accordance with the Performance Work Statement • Firm-Fixed Price CLIN • Severable Services Period of Performance 04/15/2029-04/14/2030	12 months	$	$
3002	Travel-Optional - Option Year 3 Period of Performance 04/15/2029-04/14/2030	1 Each	$	$ Not to Exceed
3003	Contract Access Fee (CAF)	1 Each	$	$

Option Period 4:

ITEM	SUPPLIES / SERVICES	QTY / UNIT	UNIT PRICE	EXTENDED PRICE
4001	Option to Extend Services 52.217-8 Option to Extend Services- May extend 1- 6 months Period of Performance: 04/15/2030-10/14/2030	6 Months		
4002	Contract Access Fee	1 Each	$	$

Base Year Total Value:	$
Option Period 1 Total Value:	$
Option Period 2 Total Value:	$
Option Period 3 Total Value:	$
Option Period 4 Total Value:	$
Total Task Order Total Value:	$

SECTION C - CONTRACT DOCUMENTS, EXHIBITS OR ATTACHMENTS

Performance Work Statement

Title: DGHP OD Office 365 Development Support

SECTION 1 – BACKGROUND

The Division of Global Health Protection is focused on streamlining, developing, and enhancing its systems and processes through the effective use of Microsoft 365 (M365) products and solutions. This initiative is designed to automate workflows and improve productivity and transparency across the division. The services requested under this contract will assist the division in achieving its operational objectives, as directed by leadership within the Office of the Director. The work performed under this contract will benefit all operating units within the Division of Global Health Protection (DGHP) at Headquarters and across Country Offices worldwide.

SECTION 2 – PURPOSE/OBJECTIVE

The contract will provide support to achieve the overall operational objectives of the Office of the Director, Division of Global Health Protection (DGHP). The requested services will include recommending best practices, demonstrating functionality, proposing enhancements, and providing clear development documentation and standard operating procedures (SOPs) tailored for the intended audience. Additionally, the contract will encompass training for government staff on the ongoing use and management of M365 products and solutions.

SECTION 3 – SCOPE OF WORK

The contractor shall provide services to design, develop, implement, and maintain Microsoft 365 (M365) solutions and products that enhance the operational efficiency of the Division of Global Health Protection (DGHP). The services will include providing support to the Office of the Director leadership and teams, project managers/officers, technical leads/subject matter experts (SMEs), and operational SMEs to ensure that the solutions meet the specific needs of the division.

The scope of services includes, but is not limited to, the following:

1. **Solution Development**: Design, analyze, develop, and maintain key components of M365 solutions using a range of M365 applications tailored to the operational requirements of DGHP.

2. **Requirements Analysis**: Participate in requirements analysis to develop comprehensive solutions across all M365 applications, including user interface, middle-tier business components, and database layers.

3. **Documentation**: Create and maintain functional design documents that translate business requirements into system requirements, ensuring clarity for stakeholders including standard operating processes (SOPs) tailored for different audiences.

4. **User Access Management**: Establish and maintain end-user access policies and permissions to ensure

secure and appropriate access to M365 solutions.

5. **Technical Support**: Provide ongoing support for M365-related issues and inquiries, ensuring timely resolution and user satisfaction.

6. **Training**: Develop and execute training programs for government staff on the effective use and ongoing management of M365 products and solutions.

7. **Collaboration**: Work closely with the Office of the Director leadership and teams, project managers/officers, technical leads/subject matter experts (SMEs), and operational SMEs to facilitate the successful implementation of M365 projects.

SECTION 4 – TASKS TO BE PERFORMED

1) **Card Readers.** The Contractor (and/or any subcontractor) shall include Federal Information Processing Standard (FIPS) 201-compliant smart card readers (referred to as LACS Transparent Readers) with the purchase of servers, printers, desktops, and laptops.

2) **Mobile Devices**. The contractor shall follow NIST 800-124, Rev. 1, *Guidelines for Managing the Security of Mobile Devices in the Enterprise* when using mobile devices that process or store HHS data.

The Contractor shall perform the following tasks:

1) The Contractor (and/or any subcontractor) shall ensure IT applications designed and developed for end users (including mobile applications and software licenses) run in the standard user context without requiring elevated administrative privileges.

2) The Contractor shall follow secure coding best practice requirements, as directed by United States Computer Emergency Readiness Team (US-CERT) specified standards and the Open Web Application Security Project (OWASP), that will limit system software vulnerability exploits.

3) The Contractor shall ensure that computer software developed on behalf of HHS or tailored from an open-source product, is fully functional and operates correctly on systems configured in accordance with government policy and federal configuration standards. The contractor shall test applicable products and versions with all relevant and current updates and patches updated prior to installing them in the HHS environment. No sensitive data shall be used during software testing.

4) The Contractor shall protect information that is deemed sensitive from unauthorized disclosure to persons, organizations or subcontractors who do not have a need to know the information. Information which, either alone or when compared with other reasonably-available information, is deemed sensitive or proprietary by HHS shall be protected as instructed in accordance with the magnitude of the loss or harm that could result from inadvertent or deliberate disclosure, alteration, or destruction of the data. This language also applies to all subcontractors that are performing under this contract.

5) The Contractor shall remediate all risks or vulnerabilities immediately after the risks or vulnerabilities have been identified in the software.

a. Service Requirement 1: Lead M365 Development Services, Office of the Director

The Contractor shall perform the following tasks:

1. Design, analyze, develop, and maintain Microsoft 365 solutions that align with the operational goals of DGHP utilizing M365 applications.

2. Conduct requirements analysis and develop comprehensive M365 solutions including user interface, middle-tier business components, and database layers.

3. Develop functional design documents that translate business requirements into system requirements and demonstrate solutions to key stakeholders including standard operating processes (SOPs) tailored for different audiences.

4. Establish and maintain end-user access policies and permissions to ensure secure access to M365 solutions.

5. Provide ongoing support for Microsoft 365-related issues and inquiries, ensuring effective resolution.

6. Create, plan, and execute training sessions for staff on the use of Microsoft 365 products and solutions.

7. Collaborate with M365 Developers, Office of the Director leadership and teams, project managers/officers, technical leads/subject matter experts (SMEs), and operational SMEs on various projects to ensure successful outcomes.

8. Serve as an administrator over DGHP's M365 applications and solutions.

9. Ensure all applications and solutions developed for DGHP are in compliance with the requirements established by the CDC and the Global Health Center.

10. The Lead M365 Developer under the DGHP Office of the Director will maintain oversight of the two M365 Developers.

b. Service Requirement 2: M365 Development Services (estimated 3,760 hours per year)

The Contractor shall be responsible for the design, development, and implementation of new Microsoft 365 products and solutions. Their tasks will include:

1. Developing M365 solutions and products by analyzing requirements and information needs, conferring with stakeholders, and studying systems flow, data usage, and work processes.

2. Engaging in development tasks that may involve workflows and a variety of tools and applications within Microsoft 365.

3. Performing maintenance for administration and security issues, including managing permissions for M365 solutions.

4. Assisting staff with Microsoft 365 issues in a helpdesk capacity, in collaboration with the Lead M365 Developer.

5. Extending and improving the functionality of current workflows within M365, while ensuring compliance with security protocols.

6. Collaborating with technical and management staff to enhance the functionality of existing solutions.

7. Creating functional design documents that translate business requirements into system requirements and demonstrating solutions to key stakeholders.

8. Establishing and maintaining end-user access policies and permissions.
9. Planning and executing training sessions for DGHP staff on Microsoft 365 products and solutions.
10. Analyzing process improvements, networking, and return on investment (ROI) to ensure that developments align with end-user needs.
11. Ensure all applications and solutions developed for DGHP are in compliance with the requirements established by the CDC and the Global Health Center.
12. Collaborating with the Lead M365 Developer for the training and deployment of Microsoft 365 solutions.

SECTION 5 – GOVERNMENT FURNISHED PROPERTY

The Government shall provide contractor personnel with an office environment typically provided to Government personnel that includes workstations, facsimile, telephones, and computers with access to the Internet and local area network (LAN). Government will issue a mobile phone, printer, and laptop if deemed necessary to complete the requirements of the task order. The government will issue a PIV Smartcard for access to necessary CDC facilities. In addition, the government will provide training specific to federal and CDC systems, regulations, and protocols as required. Contractors will be required to use secure CDC IT systems to complete work such as working over VPN, through CITGO, or accessing programs via M365 tools.

SECTION 6 – PLACE OF PERFORMANCE AND CONTRACT SUPPORT HOURS

SUBSECTION A – PLACE OF PERFORMANCE

The place of performance may be: 1. entirely off site (contractor's facility or other); or 2. at a government facility with specified allowances for telework (onsite with telework). If the place of performance is at a government facility, the locations are: 1. within the United States at the Atlanta, GA based headquarters; 2. in a foreign location; or 3. at various locations. See and refer to SECTION 7 – TRAVEL to provide further details.

SUBSECTION B – CONTRACT SUPPORT HOURS

Contract support is required on a full-time basis, requiring 40 Core Hours a week. Work will be performed 40 hours per week during the CDC hours of operation, The CDC has a flexible work program schedule that allows individuals to begin work as early as 6:30AM and end as late as 6:00 PM at the discretion of the COR. Normal business hours are 8:00 AM to 4:30 PM, Monday through Friday, except Government observed holidays.

SECTION 7 – TRAVEL

If travel is necessary, travel will be in accordance with / and not to exceed the Federal Travel Regulation rates. Travel costs need to be approved in advance by the COR. The contractor shall be required to provide their travel policy to the Government for review.

Travel does not include conferences. Conference Approval Management Systems (CAMS) approval is required in advance of any travel for conferences. If the need for conference travel occurs, the contract will be modified to separately add funding.

SECTION 8 – DELIVERABLES/REPORTING SCHEDULE

Deliverables Overview

Task	Deliverable Description	Frequency	Date of Delivery	Recipient
Initial Meeting	Conduct an initial business and technical meeting to review the goals and objectives of the contract and discuss technical requirements. A complete record of this meeting shall be delivered.	Once	Meeting to be conducted within 15 business days following contract award. Record to be delivered within 5 business days after the meeting.	Contracting Officer Representative (COR) and listed contract POCs.
Monthly Status Report	Prepare and submit a monthly technical progress report detailing the work accomplished, current issues, proposed corrective actions, and forecasts for the next period.	Monthly	By the 10th calendar day of each month.	Contracting Officer Representative (COR)
Documentation of Best Practices	Document and provide recommendations for best practices related to M365 solutions developed or maintained each month. This documentation will be submitted as part of the monthly status report.	Monthly	By the 10th calendar day of each month.	Contracting Officer Representative (COR) and listed contract POCs.
Final Report	Upon completion of all work under the contract, prepare and submit a comprehensive final report summarizing all work accomplished, including recommendations and conclusions.	Once	Due no later than 15 days prior to the end of the period of performance.	Contracting Officer Representative (COR)
Training Materials	The contractor shall develop and submit training materials tailored for government staff on the use and management of M365 products and solutions.	Ongoing	These materials will be delivered at least 10 business days prior to scheduled training sessions.	Contracting Officer Representative (COR) and listed contract POCs.
Functional Design Documents	For each M365 solution developed, the contractor shall provide functional design documents that outline the business requirements and system requirements.	Ongoing	These documents will be submitted within 5 business days of the completion of each development phase.	Contracting Officer Representative (COR) and listed contract POCs.
Detailed Timeline	Deliver a detailed timeline for each task (initiation, design/build, maintenance) in MS Project, MS Word, MS Excel, MS PowerPoint,	Monthly	Not later than the 5th day of every month.	Contracting Officer Representative (COR) and listed contract POCs.

Task	Deliverable Description	Frequency	Date of Delivery	Recipient
	or MS Visio format.			

By adhering to this deliverables and reporting schedule, the contractor will ensure that all expectations are met in a timely and organized manner, facilitating effective communication and project management throughout the contract period.

SUBSECTION A – PERFORMANCE MATRIX

Deliverable	Performance Standard/ Indicator	Acceptable Quality Levels	Surveillance Method	Incentives
Service Requirements 1 and 2	Timelines and or Quality	Service requirements and reporting shall be performed in accordance with the contract/task order terms and conditions. Services shall be conducted and completed within Program established timelines. No unresolved Contract Discrepancy Reports (CDR) for any individual service during any individual calendar month	Validated User Customer Complaints	Contractor's failure to resolve CDR within Office of Financial Resources (OFR) established timeframe shall result in a 5% reduction in Individual service's applicable overall monthly cost until such time the CDR is resolved. 5% reduction shall become effective upon vendor's receipt of CDR from OFR.

SECTION 9 – REFERENCE MATERIALS

Not applicable.

SECTION 10 – MINIMUM VENDOR QUALIFICATIONS

Not applicable.

SECTION 11 – ADDITIONAL REQUIREMENTS

Paperwork Reduction Act (PRA)
The Paperwork Reduction Act of 1995 (PRA): "Offerors are advised that any activities involving information collections (i.e., surveys, questionnaires, applications, audits, data requests, reporting, recordkeeping and disclosure requirements, etc.) from 10 or more people or non-Federal entities, including State and local governmental agencies, are subject to the conditions of the PRA. Under the PRA, a Federal agency sponsoring a

standardized information collection or directly obtaining standardized or substantially similar information from ten or more persons or entities (other than Federal employees within the scope of their employment) in any 12-month period must obtain advance written approval from the Office of Management and Budget (OMB)." Regardless of form or format (oral, written, or electronically transmitted), responses of opinion or fact requested or required by or for CDC, except those specifically exempted or excluded, are subject to the provisions of the PRA and its implementing regulation, 5 CFR 1320 (Controlling Paperwork Burdens on the Public). All such information collections must undergo OMB project determinations by CDC and may require OMB PRA clearance prior to the start of the proposed period of performance.

SECTION 12 – Section 508 and Accessibility Requirements

Electronic and Information Technology Accessibility Notice
(a) Section 508 of the Rehabilitation Act of 1973 (29 U.S.C. 794d), as amended by the Workforce Investment Act of 1998 and the Architectural and Transportation Barriers Compliance Board Electronic and Information (EIT) Accessibility Standards (36 CFR part 1194), require that when Federal agencies develop, procure, maintain, or use electronic and information technology, Federal employees with disabilities have access to and use of information and data that is comparable to the access and use by Federal employees who are not individuals with disabilities, unless an undue burden would be imposed on the agency. Section 508 also requires that individuals with disabilities, who are members of the public seeking information or services from a Federal agency, have access to and use of information and data that is comparable to that provided to the public who are not individuals with disabilities, unless an undue burden would be imposed on the agency.

K. Accordingly, any offeror responding to this solicitation must comply with established HHS EIT accessibility standards. Information about Section 508 is available at http://www.hhs.gov/web/508. The complete text of the Section 508 Final Provisions can be accessed at http://www.access-board.gov/sec508/standards.htm.

L. The Section 508 accessibility standards applicable to this contract are: 1194.

205 WCAG 2.0 Level A & AA Success Criteria

302 Functional Performance Criteria

502 Inoperability with Assistive Technology

503 Applications

504 Authoring Tools

602 Support Documentation

603 Support Services

In order to facilitate the Government's determination whether proposed EIT supplies meet applicable Section 508 accessibility standards, offerors must submit an HHS Section 508 Product Assessment Template, in accordance with its completion instructions. The purpose of the template is to assist HHS acquisition and program officials in determining whether proposed EIT supplies conform to applicable Section 508 accessibility standards. The template allows offerors or developers to self-evaluate their supplies and documentation in detail - whether they conform to a specific Section 508 accessibility standard, and any underway remediation efforts addressing conformance issues. Instructions for preparing the HHS Section 508 Evaluation Template are available under Section 508 policy on the HHS Web site http://hhs.gov/web/508.
In order to facilitate the Government's determination whether proposed EIT services meet applicable Section 508 accessibility standards, offerors must provide enough information to assist the Government in determining that the EIT services conform to Section 508 accessibility standards, including any underway remediation efforts addressing conformance issues.
(f) Respondents to this solicitation must identify any exception to Section 508 requirements. If an offeror claims its supplies or services meet applicable Section 508 accessibility standards, and it is later determined by the Government, i.e., after award of a contract or order, that supplies or services delivered do not conform to the accessibility standards, remediation of the supplies or services to the level of conformance specified in the contract will be the responsibility of the Contractor at its expense.

(g) Electronic content must be accessible to HHS acceptance criteria. Checklist for various formats is available at http://508.hhs.gov/, or from the Section 508 Coordinator listed at https://www.hhs.gov/web/section-508/additional-resources/section-508-contacts/index.html. Materials that are final items for delivery should be accompanied by the appropriate checklist, except upon approval of the Contracting Officer or Representative.

SPECIAL CONSIDERATIONS

Information Security and/or Physical Access Security

A. Baseline Security Requirements

1) **Applicability.** The requirements herein apply whether the entire contract or order (hereafter "contract"), or portion thereof, includes either or both of the following:

a. Access (Physical or Logical) to Government Information: A Contractor (and/or any subcontractor) employee will have or will be given the ability to have, routine physical (entry) or logical (electronic) access to government information.

b. Operate a Federal System Containing Information: A Contractor (and/or any subcontractor) employee will operate a federal system and information technology containing data that supports the HHS mission. In addition to the Federal Acquisition Regulation (FAR) Subpart 2.1 definition of "information technology" (IT), the term as used in this section includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources.

2) **Safeguarding Information and Information Systems.** In accordance with the Federal Information Processing Standards Publication (FIPS) 199, *Standards for Security Categorization of Federal Information and Information Systems*, the Contractor (and/or any subcontractor) shall:

a. Protect government information and information systems in order to ensure:
- **Confidentiality**, which means preserving authorized restrictions on access and disclosure, based on the security terms found in this contract, including means for protecting personal privacy and proprietary information;
- **Integrity**, which means guarding against improper information modification or destruction, and ensuring information non-repudiation and authenticity; and
- **Availability**, which means ensuring timely and reliable access to and use of information.

b. Provide security for any Contractor systems, and information contained therein, connected to an HHS network or operated by the Contractor on behalf of HHS regardless of location. In addition, if new or unanticipated threats or hazards are discovered by either the agency or contractor, or if existing safeguards have ceased to function, the discoverer shall immediately, **within one (1) hour or less**, bring the situation to the attention of the other party.

c. Adopt and implement the policies, procedures, controls, and standards required by the HHS Information Security Program to ensure the confidentiality, integrity, and availability of government information and government information systems for which the Contractor is responsible under this contract or to which the Contractor may otherwise have access under this contract. Obtain the HHS Information Security Program security requirements, outlined in the HHS Information Security and Privacy Policy (IS2P), by contacting the CO/COR or emailing fisma@hhs.gov.

d. Comply with the Privacy Act requirements and tailor FAR clauses as needed.

3) **Information Security Categorization**. In accordance with FIPS 199 and National Institute of Standards and Technology (NIST) Special Publication (SP) 800-60, *Volume II: Appendices to Guide for Mapping Types of Information and Information Systems to Security Categorie*s, Appendix C, and based on information provided by the ISSO, CISO, or other security representative, the risk level for each Security Objective and the Overall Risk Level, which is the highest watermark of the three factors (Confidentiality, Integrity, and Availability) of the information or information system are the following:

Confidentiality: [X] Low [] Moderate [ ] High
Integrity: [] Low [X] Moderate [ ] High
Availability: [X] Low [] Moderate [ ] High
Overall Risk Level: [] Low [X] Moderate [ ] High

Based on information provided by the ISSO, Privacy Office, system/data owner, or other security or privacy representative, it has been determined that this solicitation/contract involves:

[X] No PII [] Yes PII

4) **Personally Identifiable Information (PII).** Per the Office of Management and Budget (OMB) Circular A-130, "PII is information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual." Examples of PII include, but are not limited to the following: social security number, date and place of birth, mother's maiden name, biometric records, etc.

PII Confidentiality Impact Level has been determined to be: [ ] Low [] Moderate [ ] High

5) **Controlled Unclassified Information (CUI).** CUI is defined as "information that laws, regulations, or Government-wide policies require to have safeguarding or dissemination controls, excluding classified information." The Contractor (and/or any subcontractor) must comply with *Executive Order 13556, Controlled Unclassified Information, (implemented at 32 CFR,* part 2002*)* when handling CUI. 32 C.F.R. 2002.4(aa) As implemented the term "h*andling"* refers to "…any use of CUI, including but not limited to marking, safeguarding, transporting, disseminating, re-using, and disposing of the information." 81 Fed. Reg. 63323. All sensitive information that has been identified as CUI by a regulation or statute, handled by this solicitation/contract, shall be:

a. marked appropriately;

b. disclosed to authorized personnel on a Need-To-Know basis;

c. protected in accordance with NIST SP 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations* applicable baseline if handled by a Contractor system operated on behalf of the agency, or NIST SP 800-171, *Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations* if handled by internal Contractor system; and

d. returned to HHS control, destroyed when no longer needed, or held until otherwise directed.

Destruction of information and/or data shall be accomplished in accordance with NIST SP 800-88*, Guidelines for Media Sanitization*.

6) **Protection of Sensitive Information**. For security purposes, information is *or* may be sensitive because it requires security to protect its confidentiality, integrity, and/or availability. The Contractor (and/or any subcontractor) shall protect all government information that is or may be sensitive in accordance with OMB

Memorandum M-06-16, *Protection of Sensitive Agency Information* by securing it with a FIPS 140-2 validated solution.

7) **Confidentiality and Nondisclosure of Information**. Any information provided to the contractor (and/or any subcontractor) by HHS or collected by the contractor on behalf of HHS shall be used only for the purpose of carrying out the provisions of this contract and shall not be disclosed or made known in any manner to any persons except as may be necessary in the performance of the contract. The Contractor assumes responsibility for protection of the confidentiality of Government records and shall ensure that all work performed by its employees and subcontractors shall be under the supervision of the Contractor. Each Contractor employee or any of its subcontractors to whom any HHS records may be made available or disclosed shall be notified in writing by the Contractor that information disclosed to such employee or subcontractor can be used only for that purpose and to the extent authorized herein.
The confidentiality, integrity, and availability of such information shall be protected in accordance with HHS and *[CDC]* policies. Unauthorized disclosure of information will be subject to the HHS/*[CDC]* sanction policies and/or governed by the following laws and regulations:

a. 18 U.S.C. 641 (Criminal Code: Public Money, Property or Records);
b. 18 U.S.C. 1905 (Criminal Code: Disclosure of Confidential Information); and
c. 44 U.S.C. Chapter 35, Subchapter I (Paperwork Reduction Act).

8) **Internet Protocol Version 6 (IPv6).** All procurements using Internet Protocol shall comply with OMB Memorandum M-05-22, *Transition Planning for Internet Protocol Version 6 (IPv6)*.

9) **Government Websites.** All new and existing public-facing government websites must be securely configured with Hypertext Transfer Protocol Secure (HTTPS) using the most recent version of Transport Layer Security (TLS). In addition, HTTPS shall enable HTTP Strict Transport Security (HSTS) to instruct compliant browsers to assume HTTPS at all times to reduce the number of insecure redirects and protect against attacks that attempt to downgrade connections to plain HTTP. For internal-facing websites, the HTTPS is not required, but it is highly recommended.

10) **Contract Documentation**. The Contractor shall use provided templates, policies, forms and other agency documents to comply with contract deliverables as appropriate.

Document	Deliverable Title/Description	Due Date
Roster	Roster	By effective date of this contract
Contractor Employee Non-Disclosure Agreement (NDA)	Contractor Employee Non-Disclosure Agreement (NDA)	Prior to performing any work on behalf of HHS
Privacy Threshold Analysis (PTA)/ Privacy Impact Assessment (PIA)	Assist in the completion of a PTA/PIA form	In conjunction with contract award
Training Records	Copy of training records for all mandatory training	In conjunction with contract award and annually thereafter or upon request
Rules of Behavior	Signed ROB for all employees	Initiation of contract and at least annually thereafter
Incident Response	Incident Report (as incidents or breaches occur)	As soon as possible and without reasonable delay and no later than 1 hour of discovery
Incident Response	Incident and Breach Response Plan	Upon request from government
Personnel Security Responsibilities	List of Personnel with defined roles and responsibilities	Prior to performing any work on behalf of HHS
Personnel Security Responsibilities	Off-boarding documentation, equipment and badge when leaving contract	Prior to performing any work on behalf of HHS
Background Investigation	Onboarding documentation when beginning contract	Prior to performing any work on behalf of HHS
Certification of Sanitization of Government and Government Activity-Related Files, Information, and Devices	Form or deliverables required by CDC	At contract expiration
Contract Initiation and Expiration	If the procurement involves a system or cloud service, additional documentation will be required, such as Disposition/Decommission Plan	At contract expiration

11) **Standard for Encryption.** The Contractor (and/or any subcontractor) shall:

a. Comply with the *HHS Standard for Encryption of Computing Devices and Information* to prevent unauthorized access to government information.

b. Encrypt all sensitive federal data and information (i.e., PII, protected health information [PHI], proprietary information, etc.) in transit (i.e., email, network connections, etc.) and at rest (i.e., servers, storage devices, mobile devices, backup media, etc.) with FIPS 140-2 validated encryption solution.

c. Secure all devices (i.e.: desktops, laptops, mobile devices, etc.) that store and process government information and ensure devices meet HHS and CDC-specific encryption standard requirements. Maintain a complete and current inventory of all laptop computers, desktop computers, and other mobile devices and portable media that store or process sensitive government information (including PII).

d. Verify that the encryption solutions in use have been validated under the Cryptographic Module Validation Program to confirm compliance with FIPS 140-2. The Contractor shall provide a written copy of the validation documentation to the COR.

e. Use the Key Management system on the HHS personal identification verification (PIV) card or establish and use a key recovery mechanism to ensure the ability for authorized personnel to encrypt/decrypt information and recover encryption keys. Encryption keys shall be provided to CDC Office of Chief Information Security Officer (OCISO).

12) **Contractor Non-Disclosure Agreement (NDA)**. Each Contractor (and/or any subcontractor) employee having access to non-public government information under this contract shall complete the CDC non-disclosure agreement, as applicable. A copy of each signed and witnessed NDA shall be submitted to the Contracting Officer (CO) and/or CO Representative (COR) prior to performing any work under this acquisition.

13) **Privacy Threshold Analysis (PTA)/Privacy Impact Assessment (PIA)** – The Contractor shall assist the CDC Senior Official for Privacy (SOP) or designee with conducting a PTA for the information system and/or information handled under this contract in accordance with HHS policy and OMB M-03-22, Guidance for Implementing the Privacy Provisions of the E-Government Act of 2002.

a. The Contractor shall assist the CDC SOP or designee in reviewing the PIA at least every three years throughout the system development lifecycle (SDLC)/information lifecycle, or when determined by the CDC SOP that a review is required based on a major change to the system (e.g., new uses of information collected, changes to the way information is shared or disclosed and for what purpose, or when new types of PII are collected that could introduce new or increased privacy risks), whichever comes first.

B. Training

1) **Mandatory Training for All Contractor Staff.** All Contractor (and/or any subcontractor) employees assigned to work on this contract shall complete the applicable HHS/CDC Contractor Information Security Awareness, Privacy, and Records Management training (provided upon contract award) before performing any work under this contract. Thereafter, the employees shall complete *CDC Security Awareness Training (SAT), Privacy,* and Records Management training at least ***annually***, during the life of this contract. All provided training shall be compliant with HHS training policies.

2) **Role-based Training.** All Contractor (and/or any subcontractor) employees with significant security responsibilities (as determined by the program manager) must complete role-based training (RBT) ***within 60 days*** of assuming their new responsibilities. Thereafter, they shall complete RBT at least ***annually*** in accordance with HHS policy and the *HHS Role-Based Training (RBT) of Personnel with Significant Security Responsibilities Memorandum*.

All HHS employees and contractors with SSR who ***have not*** completed the required training within the mandated timeframes shall have their user accounts disabled until they have met their RBT requirement.

3) **Training Records.** The Contractor (and/or any subcontractor) shall maintain training records for all its employees working under this contract in accordance with HHS policy. A copy of the training records shall be provided to the CO and/or COR within ***30 days*** after contract award and ***annually*** thereafter or upon request.

C. Rules of Behavior

1) The Contractor (and/or any subcontractor) shall ensure that all employees performing on the contract comply with the *HHS Information Technology General Rules of Behavior.*

2) All Contractor employees performing on the contract must read and adhere to the Rules of Behavior before accessing Department data or other information, systems, and/or networks that store/process

government information, initially at the beginning of the contract and at least ***annually*** thereafter, which may be done as part of annual *CDC Security Awareness Training*. If the training is provided by the contractor, the signed ROB must be provided as a separate deliverable to the CO and/or COR per defined timelines above.

D. Incident Response

FISMA defines an incident as "an occurrence that (1) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or (2) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies. The HHS *Policy for IT Security and Privacy Incident Reporting and Response* further defines incidents as events involving cybersecurity and privacy threats, such as viruses, malicious user activity, loss of, unauthorized disclosure or destruction of data, and so on.

A privacy breach is a type of incident and is defined by Federal Information Security Modernization Act (FISMA) as the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (1) a person other than an authorized user accesses or potentially accesses personally identifiable information or (2) an authorized user accesses or potentially accesses personally identifiable information for an other than authorized purpose.

OMB Memorandum M-17-12, "Preparing for and Responding to a Breach of Personally Identifiable Information" (03 January 2017) states:

Definition of an Incident:

An occurrence that (1) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or (2) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies.

Definition of a **Breach:**

The loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (1) a person other than an authorized user accesses or potentially accesses personally identifiable information or (2) an authorized user accesses or potentially accesses personally identifiable information for an other than authorized purpose.

It further adds:

A breach is not limited to an occurrence where a person other than an authorized user potentially accesses PII by means of a network intrusion, a targeted attack that exploits website vulnerabilities, or an attack executed through an email message or attachment. A breach may also include the loss or theft of physical documents that include PII and portable electronic storage media that store PII, the inadvertent disclosure of PII on a public website, or an oral disclosure of PII to a person who is not authorized to receive that information. It may also include an authorized user accessing PII for an other than authorized purpose.

The HHS *Policy for IT Security and Privacy Incident Reporting and Response* further defines a breach as "a suspected or confirmed incident involving PII".

Contracts with entities that collect, maintain, use, or operate Federal information or information systems on behalf of CDC shall include the following requirements:

1) The contractor shall cooperate with and exchange information with CDC officials, as deemed necessary by the CDC Breach Response Team, to report and manage a suspected or confirmed breach.

2) All contractors and subcontractors shall properly encrypt PII in accordance with OMB Circular A-130 and other applicable policies, including CDC-specific policies, and comply with HHS-specific policies for protecting PII. To this end, all contractors and subcontractors shall protect all sensitive information, including any PII created, stored, or transmitted in the performance of this

contract so as to avoid a secondary sensitive information incident with FIPS 140-2 validated encryption.

3) All contractors and subcontractors shall participate in regular training on how to identify and report a breach.

4) All contractors and subcontractors shall report a suspected or confirmed breach in any medium as soon as possible and no later than 1 hour of discovery, consistent with applicable CDC IT acquisitions guidance, HHS/CDC and incident management policy, and United States Computer Emergency Readiness Team (US-CERT) notification guidelines. To this end, the Contractor (and/or any subcontractor) shall respond to all alerts/Indicators of Compromise (IOCs) provided by HHS Computer Security Incident Response Center (CSIRC) or CDC Computer Incident Response Team (CSIRT) within 24 hours via email at csirt@cdc.gov or telephone at 866-655-2245, whether the response is positive or negative.

5) All contractors and subcontractors shall be able to determine what Federal information was or could
have been accessed and by whom, construct a timeline of user activity, determine methods and techniques used to access Federal information, and identify the initial attack vector.

6) All contractors and subcontractors shall allow for an inspection, investigation, forensic analysis, and any other action necessary to ensure compliance with HHS/CDC Policy and the HHS/CDC Breach Response Plan and to assist with responding to a breach.

7) Cloud service providers shall use guidance provided in the FedRAMP Incident Communications Procedures when deciding when to report directly to US-CERT first or notify CDC first.

8) Identify roles and responsibilities, in accordance with HHS/CDC Breach Response Policy and the HHS/CDC Breach Response Plan. To this end, the Contractor shall NOT notify affected individuals unless and until so instructed by the Contracting Officer or designated representative. If so instructed by the Contracting Officer or representative, all notifications must be pre-approved by the appropriate CDC officials, consistent with HHS/CDC Breach Response Plan, and the Contractor shall then send CDC- approved notifications to affected individuals; and,

9) Acknowledge that CDC will not interpret report of a breach, by itself, as conclusive evidence that the contractor or its subcontractor failed to provide adequate safeguards for PII.

E. Position Sensitivity Designations

All Contractor (and/or any subcontractor) employees must obtain a background investigation commensurate with their position sensitivity designation that complies with Parts 1400 and 731 of Title 5, Code of Federal Regulations (CFR). The following position sensitivity designation levels apply to this solicitation/contract:

Tier 1 Low-Risk Non-Sensitive, including HSPD-12 Credentialing

F. Homeland Security Presidential Directive (HSPD)-12

The Contractor (and/or any subcontractor) and its employees shall comply with Homeland Security Presidential Directive (HSPD)-12, *Policy for a Common Identification Standard for Federal Employees and Contractors*; OMB M-05-24; FIPS 201, *Personal Identity Verification (PIV) of Federal Employees and Contractors*; HHS HSPD-12 policy; and *Executive Order 13467, Part 1 §1.2.*

For additional information, see HSPD-12 policy at: https://www.dhs.gov/homeland-security-presidential-directive-12)

Roster. The Contractor (and/or any subcontractor) shall submit a roster by name, position, e-mail address, phone number and responsibility of all staff working under this acquisition where the Contractor will develop, have the ability to access, or host and/or maintain a government information system(s). The roster shall be submitted to the COR and/or CO by the effective date of this contract. Any revisions to the roster as a result of staffing changes shall be submitted immediately upon change. The COR will notify the Contractor of the appropriate level of investigation required for each staff member.

If the employee is filling a new position, the Contractor shall provide a position description and the Government will determine the appropriate suitability level.

G. Contract Initiation and Expiration

1) **General Security Requirements.** The Contractor (and/or any subcontractor) shall comply with information security and privacy requirements, Enterprise Performance Life Cycle (EPLC) processes, HHS Enterprise Architecture requirements to ensure information is appropriately protected from initiation to expiration of the contract. All information systems development or enhancement tasks supported by the contractor shall follow the HHS EPLC framework and methodology and in accordance with the HHS Contract Closeout Guide (2012).

HHS EA requirements may be located here: https://www.hhs.gov/ocio/ea/documents/proplans.html
CDC EPC Requirements: https://www2a.cdc.gov/CDCup/library/other/eplc.htm

2) **System Documentation.** Contractors (and/or any subcontractors) must follow and adhere to NIST SP 800-64, *Security Considerations in the System Development Life Cycle*, at a minimum, for system development and provide system documentation at designated intervals (specifically, at the expiration of the contract) within the EPLC that require artifact review and approval.

3) **Sanitization of Government Files and Information.** As part of contract closeout and at expiration of the contract, the Contractor (and/or any subcontractor) shall provide all required documentation to the CO and/or COR to certify that, at the government's direction, all electronic and paper records are appropriately disposed of and all devices and media are sanitized in accordance with NIST SP 800-88, *Guidelines for Media Sanitization*.

4) **Notification.** The Contractor (and/or any subcontractor) shall notify the CO and/or COR and system ISSO before an employee stops working under this contract.

5) **Contractor Responsibilities Upon Physical Completion of the Contract**. The contractor (and/or any subcontractors) shall return all government information and IT resources (i.e., government information in non-government-owned systems, media, and backup systems) acquired during the term of this contract to the CO and/or COR. Additionally, the Contractor shall provide a certification that all government information has been properly sanitized and purged from Contractor-owned systems, including backup systems and media used during contract performance, in accordance with HHS and/or *CDC* policies.

6) The Contractor (and/or any subcontractor) shall perform and document the actions identified in the CDC Out-Processing Checklist (http://intranet.cdc.gov/od/hcrmo/pdfs/hr/Out_Processing_Checklist.pdf) when an employee terminates work under this contract. All documentation shall be made available to the CO and/or COR upon request.

H. Records Management and Retention

The Contractor (and/or any subcontractor) shall maintain all information in accordance with Executive Order 13556 -- Controlled Unclassified Information, National Archives and Records Administration (NARA) records retention policies and schedules and HHS policies and shall not dispose of any records unless authorized by HHS.

In the event that a contractor (and/or any subcontractor) accidentally disposes of or destroys a record without proper authorization, it shall be documented and reported as an incident in accordance with HHS policies.

SECTION D – CONTRACT CLAUSES

All Applicable and Required provisions/clauses set forth in FAR 52.3 automatically flow down to all GSA 8(a) STARS III task orders, based on their specific contract type (e.g. Cost, fixed price, etc.), statement of work, competition requirements, and dollar value as of the date the task order solicitation is issued. Representation and Certification Provisions from the GSA STARS III master contracts automatically flow down to all GSA STARS III task orders.

FAR Optional and Agency Specific Task Order Provisions/Clauses. The following additional provisions and clauses apply to this task order:

Clauses Incorporated by Full Text:

FAR 52.217-8 Option to Extend Services (Nov 1999)

The Government may require continued performance of any services within the limits and at the rates specified in the contract. These rates may be adjusted only as a result of revisions to prevailing labor rates provided by the Secretary of Labor. The option provision may be exercised more than once, but the total extension of performance hereunder shall not exceed 6 months. The Contracting Officer may exercise the option by written notice to the Contractor within 15 days.

(End of Clause)

FAR 52.217-9 Option to Extend the Term of the Contract (Mar 2000)

(a) The Government may extend the term of this contract by written notice to the Contractor within 5 days; provided, that the Government gives the Contractor a preliminary written notice of its intent to extend at least 15 days before the contract expires. The preliminary notice does not commit the Government to an extension.

(b) If the Government exercises this option, the extended contract shall be considered to include this option clause.

(c) The total duration of this contract, including the exercise of any options under this clause, shall not exceed 60 months.

(End of Clause)

52.227-17 Rights in Data-Special Works (Dec 2007)
(a) *Definitions*. As used in this clause-
Data means recorded information, regardless of form or the media on which it may be recorded. The term includes technical data and computer software. The term does not include information incidental to contract administration, such as financial, administrative, cost or pricing, or management information.
Unlimited rights means the rights of the Government to use, disclose, reproduce, prepare derivative works, distribute copies to the public, and perform publicly and display publicly, in any manner and for any purpose, and to have or permit others to do so.
(b) Allocation of Rights.
(1) The Government shall have-
(i) Unlimited rights in all data delivered under this contract, and in all data first produced in the performance of this contract, except as provided in paragraph (c) of this clause.
(ii) The right to limit assertion of copyright in data first produced in the performance of this contract, and to obtain assignment of copyright in that data, in accordance with paragraph (c)(1) of this clause.
(iii) The right to limit the release and use of certain data in accordance with paragraph (d) of this clause.

(2) The Contractor shall have, to the extent permission is granted in accordance with paragraph (c)(1) of this clause, the right to assert claim to copyright subsisting in data first produced in the performance of this contract.
(c) Copyright-
(1) Data first produced in the performance of this contract.
(i) The Contractor shall not assert or authorize others to assert any claim to copyright subsisting in any data first produced in the performance of this contract without prior written permission of the Contracting Officer. When copyright is asserted, the Contractor shall affix the appropriate copyright notice of 17 U.S.C. 401 or 402 and acknowledgment of Government sponsorship (including contract number) to the data when delivered to the Government, as well as when the data are published or deposited for registration as a published work in the U.S. Copyright Office. The Contractor grants to the Government, and others acting on its behalf, a paid-up, nonexclusive, irrevocable, worldwide license for all delivered data to reproduce, prepare derivative works, distribute copies to the public, and perform publicly and display publicly, by or on behalf of the Government.
(ii) If the Government desires to obtain copyright in data first produced in the performance of this contract and permission has not been granted as set forth in paragraph (c)(1)(i) of this clause, the Contracting Officer shall direct the Contractor to assign (with or without registration), or obtain the assignment of, the copyright to the Government or its designated assignee.
(2) *Data not first produced in the performance of this contract.* The Contractor shall not, without prior written permission of the Contracting Officer, incorporate in data delivered under this contract any data not first produced in the performance of this contract and that contain the copyright notice of 17 U.S.C. 401 or 402, unless the Contractor identifies such data and grants to the Government, or acquires on its behalf, a license of the same scope as set forth in paragraph (c)(1) of this clause.
(d) *Release and use restrictions.* Except as otherwise specifically provided for in this contract, the Contractor shall not use, release, reproduce, distribute, or publish any data first produced in the performance of this contract, nor authorize others to do so, without written permission of the Contracting Officer.
(e) *Indemnity*. The Contractor shall indemnify the Government and its officers, agents, and employees acting for the Government against any liability, including costs and expenses, incurred as the result of the violation of trade secrets, copyrights, or right of privacy or publicity, arising out of the creation, delivery, publication, or use of any data furnished under this contract; or any libelous or other unlawful matter contained in such data. The provisions of this paragraph do not apply unless the Government provides notice to the Contractor as soon as practicable of any claim or suit, affords the Contractor an opportunity under applicable laws, rules, or regulations to participate in the defense of the claim or suit, and obtains the Contractor's consent to the settlement of any claim or suit other than as required by final decree of a court of competent jurisdiction; and these provisions do not apply to material furnished to the Contractor by the Government and incorporated in data to which this clause applies.

(END OF CLAUSE)

HHSAR 352.203-70 Anti-Lobbying

Pursuant to the HHS annual appropriations acts, except for normal and recognized executive-legislative relationships, the Contractor shall not use any HHS contract funds for:
(a) Publicity or propaganda purposes;
(b) The preparation, distribution, or use of any kit, pamphlet, booklet, publication, electronic communication, radio, television, or video presentation designed to support or defeat the enactment of legislation before the Congress or any State or local legislature or legislative body, except in presentation to the Congress or any state or local legislature itself; or designed to support or defeat any proposed or pending regulation, administrative action, or order issued by the executive branch of any state or local government, except in presentation to the executive branch of any state or local government itself; or (c) Payment of salary or expenses of the Contractor, or any agent acting for the Contractor, related to any activity designed to influence the enactment of legislation, appropriations, regulation, administrative action, or Executive order proposed or pending before the Congress or any state government, state legislature or local legislature or legislative body, other than for normal and recognized executive-legislative relationships or participation by an agency or officer of a state, local, or tribal government in policymaking and administrative processes within the executive branch of that government.
(d) The prohibitions in subsections (a), (b), and (c) above shall include any activity to advocate or promote any proposed, pending, or future federal, state, or local tax increase, or any proposed, pending, or future requirement for, or restriction on, any legal consumer product, including its sale or marketing, including, but not limited to, the advocacy or promotion of gun control.

(End of clause)

HHSAR 352.204-71 Information and Information Systems Security (FEB 2024)(DEVIATION)

(a) *Definitions*. As used in this clause —

Breach means the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where —

(1) A person other than an authorized user accesses or potentially accesses personally identifiable information, or

(2) An authorized user accesses personally identifiable information for an other than authorized purpose.

Business associate (see 45 CFR 160.103), except as provided in paragraph (2) of this definition, business associate means, with respect to a covered entity, a person who —

(1) On behalf of such covered entity or of an organized health care arrangement (as defined in this clause) in which the covered entity participates, but other than in the capacity of a member of the workforce of such covered entity or arrangement, creates, receives, maintains, or transmits protected health information for a function or activity regulated by this contract or agreement, including claims processing or administration, data analysis, processing or administration, utilization review, quality assurance, patient safety activities listed at 42 CFR 3.20, billing, benefit management, practice management, and repricing; or

(2) Provides, other than in the capacity of a member of the workforce of such covered entity, legal, actuarial, accounting, consulting, data aggregation (as defined in 45 CFR section 164.501), management, administrative, accreditation, or financial services to or for such covered entity, or to or for an organized health care arrangement in which the covered entity participates, where the provision of the service involves the disclosure of protected health information from such covered entity or arrangement, or from another business associate of such covered entity or arrangement, to the person.

(3) A covered entity may be a business associate of another covered entity.

(4) *Business associate* includes the following:

(i) A Health Information Organization, E-prescribing Gateway, or other person that provides data transmission services with respect to protected health information to a covered entity and that requires access on a routine basis to such protected health information.

(ii) A person that offers a personal health record to one or more individuals on behalf of a covered entity.

(iii) A subcontractor that creates, receives, maintains, or transmits protected health information on behalf of the business associate.

(5) *Business associate* does not include:

(i) A health care provider, with respect to disclosures by a covered entity to the health care provider concerning the treatment of the individual.

(ii) A plan sponsor, with respect to disclosures by a group health plan (or by a health insurance issuer or HMO with respect to a group health plan) to the plan sponsor, to the extent that the requirements of 45 CFR 164.504(f) apply and are met.

(iii) A government agency, with respect to determining eligibility for, or enrollment in, a government health plan that provides public benefits and is administered by another government agency, or collecting protected health information for such purposes, to the extent such activities are authorized by law.

(iv) A covered entity participating in an organized health care arrangement that performs a function or activity as described by paragraph (1)(i) of this definition for or on behalf of such organized health care arrangement, or that provides a service as described in paragraph (1)(ii) of this definition to or for such organized health care arrangement by virtue of such activities or services.

Business associate agreement means the agreement, or other arrangement, as dictated by the HIPAA Privacy Rule (45 CFR 160), between an HHS covered entity and a business associate, which must be entered into in addition to the underlying contract for services and before any disclosure (see 45 CFR 160.103) of PHI can be made to the business associate, in order for the business associate to perform certain functions or activities on behalf of an HHS entity.

Controlled unclassified information (CUI) means information that laws, regulations, or Government-wide policies require to have safeguarding or dissemination controls, excluding classified information.

Healthcare component means a component or combination of components of a hybrid entity designated by the hybrid entity in accordance with 45 CFR 164.105(a)(2)(iii)(D) (see 45 CFR 164.103). The Secretary of HHS has designated HHS as a covered entity (further designated as a "hybrid entity"), and has also designated four HHS divisions as healthcare components under HIPAA, including —
(1) The Centers for Medicare and Medicaid Services (CMS), insofar as it operates the fee-for-service Medicare program;

(2) The Program Support Center (PSC), Division of Commissioned Personnel, insofar as it operates a health plan for Commissioned Corps officers;

(3) The World Trade Center (WTC) Health Program; and,

(4) The Indian Health Service (IHS), insofar as it operates a health plan and a program providing healthcare that uses electronic transactions.

HHS Information Technology General Rules of Behavior means a set of HHS rules that describes the responsibilities and expected behavior of users of HHS information or information systems.

HHS sensitive information means all HHS data, on any storage media or in any form or format, which requires confidentiality, integrity, and availability protection due to the risk of harm that could result to interests of HHS, other agencies or entities, or individuals from inadvertent or deliberate disclosure, alteration, or destruction of the information.

The term includes —
(1) Information where the improper use or disclosure could adversely affect the ability of HHS to accomplish its mission, *i.e.*, HHS proprietary information;

(2) Records about individuals requiring protection under laws and regulations such as the E- Government Act, Privacy Act and the HIPAA Privacy Rule, or based on a data use agreement or a promise or assurance of confidentiality; and

(3) Information that would be exempt from disclosure if requested under the Freedom of Information Act. Examples of HHS sensitive information include —

(i) Individually-identifiable medical, benefits, and personnel information;

(ii) Financial, budgetary, research, quality assurance, confidential commercial, critical infrastructure, security-sensitive, procurement-sensitive, investigatory, and law enforcement information;

(iii) Controlled unclassified information;

(iv) Information that would be confidential and privileged in litigation such as information protected by the deliberative process privilege, attorney work-product privilege, and the attorney- client privilege; and

(v) Other information which, if released, could result in a violation of law or agreement, could cause harm or unfairness to any individual or group, or could adversely affect the national interest or the conduct of Federal programs.

HIPAA Rules means the Privacy, Security, Breach Notification, and Enforcement Rules at 45 CFR Part 160 and part 164.

Incident means an occurrence that (A) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information systems; or (B) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable policies.

Information system means a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.

Information system security plan means a formal document that provides an overview of the security requirements for an information system or an information security program and describes the security controls in place or planned for meeting those requirements.

Information technology (see FAR 2.101) also means Information and Communication Technology (ICT).

Information technology-related contracts means those contracts that include services (including support services), and related resources for information technology.

Organized health care arrangement (see 45 CFR 160.103) means:
(1) A clinically integrated care setting in which individuals typically receive health care from more than one health care provider;

(2) An organized system of health care in which more than one covered entity participates and in which the participating covered entities:

(i) Hold themselves out to the public as participating in a joint arrangement; and

(ii) Participate in joint activities that include at least one of the following:

(A) Utilization review, in which health care decisions by participating covered entities are reviewed by other participating covered entities or by a third party on their behalf;

(B) Quality assessment and improvement activities, in which treatment provided by participating covered entities is assessed by other participating covered entities or by a third party on their behalf; or

(C) Payment activities, if the financial risk for delivering health care is shared, in part or in whole, by participating covered entities through the joint arrangement and if protected health information created or received by a covered entity is reviewed by other participating covered entities or by a third party on their behalf for the purpose of administering the sharing of financial risk.

(3) A group health plan and a health insurance issuer or HMO with respect to such group health plan, but only with respect to protected health information created or received by such health insurance issuer or HMO that relates to individuals who are or who have been participants or beneficiaries in such group health plan;

(4) A group health plan and one or more other group health plans each of which are maintained by the same plan sponsor; or

(5) The group health plans described in paragraph (4) of this definition and health insurance issuers or HMOs with respect to such group health plans, but only with respect to protected health information created or received by such health insurance issuers or HMOs that relates to individuals who are or have been participants or beneficiaries in any of such group health plans.

Privacy officer means the HHS official(s) with responsibility for implementing and oversight of privacy related policies and practices that impact a given HHS acquisition.

(b) *General*. Contractors, subcontractors, their employees, third-parties, and business associates with access to HHS information, information systems, or information technology (IT) or providing and accessing IT-related goods and services, shall adhere to the HHS Cybersecurity Program and the directives and handbooks, complete HHS security training prior to accessing HHS information (including HHS sensitive information and information systems security and privacy) and on an annual basis thereafter, as well as those set forth in the contract specifications, statement of work, or performance work statement. These include, but are not limited to, HHS *Personnel Security and Suitability Program*, which establishes HHS procedures, responsibilities, and processes for complying with current Federal law, Executive Orders, policies, regulations, standards, and guidance for protecting HHS information, information systems (see 302.101, Definitions) security and privacy, and adhering to personnel security requirements when accessing HHS information or information systems.

(c) *Access to HHS information and HHS information systems*.

(1) Contractors are limited in their request for logical or physical access to HHS information or HHS information systems for their employees, subcontractors, third parties and business associates to the extent necessary to perform the services or provide the goods as specified in the contracts, agreements, task, delivery, or purchase orders.

(2) All Contractors, subcontractors, third parties, and business associates working with HHS information are subject to the same investigative requirements as those of HHS appointees or employees who have access to the same types of information. The level and process of background security investigations for Contractors to access HHS information and HHS information systems shall be in accordance with HHS *Personnel Security and Suitability Program*.

(3) Contractors, subcontractors, third parties, and business associates who require access to national security programs must have a valid security clearance.

(4) The Contractor (and/or any subcontractor) must comply with *Executive Order 13556, Controlled Unclassified Information, (implemented at 3 CFR,* part 2002*)* when handling CUI. 32 C.F.R. 2002.4(aa) As implemented the term "*handling*" refers to "…any use of CUI, including but not limited to marking, safeguarding, transporting, disseminating, re-using, and disposing of the information." 81 Fed. Reg. 63323. The requirements below apply only to nonfederal systems that process, store, or transmit CUI, or that provide security protection for such components. All sensitive information that has been identified as CUI by a regulation or statute, handled by this solicitation/contract, must be —

(i) Marked appropriately;

(ii) Disclosed to authorized personnel on a need-to-know basis;

(iii) Protected in accordance with NIST SP 800-53, *Security and Privacy Controls for Information Systems and Organizations* applicable baseline if handled by a Contractor system operated on behalf of the agency, or NIST SP 800-171, *Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations* if handled by internal Contractor system; and
(iv) Returned to HHS control, destroyed when no longer needed, or held until otherwise directed. Information and/or data must be disposed of in accordance with NIST SP 800-88, *Guidelines for Media Sanitization*.

(5) *HIPAA business associate agreements*. Under the HIPAA Privacy and Security Rules (see 45 CFR 164), pursuant to 45 CFR 164.502(e)(1), a covered entity may disclose protected health information to a business associate and may allow a business associate to create, receive, maintain, or transmit protected health information on its behalf, if the covered entity obtains satisfactory assurance that the business associate will appropriately safeguard the information. A covered entity is not required to obtain such satisfactory assurances from a business associate that is a subcontractor of a covered entity's business associate. Additionally, a business associate may disclose protected health information to a business associate that is a subcontractor and may allow the subcontractor to create, receive, maintain, or transmit protected health information on its behalf, if the business associate obtains satisfactory assurances, in accordance with 45 CFR 164.504(e)(1)(i), that the subcontractor will appropriately safeguard the information. The satisfactory assurances required by 45 CFR 45 CFR 164.504(e)(1) of this section shall be documented through a written contract or other written agreement or arrangement with the business associate that

meets the applicable requirements of 45 CFR 164.504(e). The contracts shall also include breach reporting policies and procedures for suspected or confirmed breaches of protected health information. The contract shall impose a duty to cooperate with the healthcare component and/or HHS breach investigation and response and must require all subcontractors to comply with the same HIPAA Rules requirements as a condition of receiving government data.

(i) *Contractors or entities required to execute business associate agreements for contracts and other agreements become HHS business associates*. Business associate agreements are issued by HHS or may be issued by other HHS programs in support of HHS. The HIPAA Privacy Rule requires HHS to execute compliant business associate agreements with persons or entities that create, receive, maintain, or transmit HHS PHI or that will store, generate, access, exchange, process, or utilize such PHI in order to perform certain activities, functions or services to, for, or on behalf of HHS. There may be other HHS components or staff offices which also provide certain services and support to HHS and must receive PHI in order to do so. If these components award contracts or enter into other agreements, purchase /delivery orders, modifications and issue governmentwide purchase card transactions to help in the delivery of these services to HHS, they will also fall within the requirement to obtain a satisfactory assurance from these contractors by executing a business associate agreements.

(ii) *Business associate agreement flow down to subcontractors*. A prime contractor required to execute a business associate agreement shall also obtain a satisfactory assurance, in the form of a business associate agreement, of its subcontractors who will also create, receive, maintain, or transmit PHI or that will store, generate, access, exchange, process, or utilize such PHI will comply with HIPAA Rules requirements to the same degree as the Contractor. A contractor employing a subcontractor who creates, receives, maintains, or transmits PHI or that will store, generate, access, exchange, process, or utilize such PHI under a contract or agreement is required to execute a business associate agreement with each of its subcontractors which also obligates the subcontractor (i.e., also a business associate) to provide the same protections and safeguards and agree to the same disclosure restrictions to PHI that is required of the covered entity and the prime contractor.

(d) *Contractor operations required to be in United States*. Custom software development and outsourced operations must be located in the U.S. to the maximum extent practicable. If such services are proposed to be performed outside the continental United States, and are not otherwise disallowed by other Federal law, regulations or policy, or other HHS policy or other mandates as stated in the contract, specifications, statement of work or performance work statement (including applicable business associate agreements), the Contractor/subcontractor must state in its proposal where all non-U.S. services are provided. At a minimum, the Contractor/subcontractor must include a detailed Information System Security Plan, for review and approval by the Contracting Officer, specifically to address mitigation of the resulting problems of communication, control, and data protection.

(e) *Roster of employees*. Contractors and subcontractors shall provide a roster containing the name, position, e- mail address, phone number, and responsibilities of each employee, including subcontractors, performing work under the contract to develop, have the ability to access, or host and/or maintain a government information system(s). The roster must be submitted to Contracting Officer within *to be determined* days stated number of days from the effective date of the contract. Revisions to the roster as a result of staffing changes must be submitted within the number of days of the change provided by the Contracting Officer. The Contracting

Officer, or the Contracting Officer's Representative (COR), will notify the Contractor of the appropriate level of investigation required for each staff member based on the information provided on the roster. If an employee is filling a new position, the Contractor must provide a position description and the Government will determine the appropriate suitability level.

(f) *Contractor/subcontractor employee reassignment and termination notification*. Contractors and subcontractors shall provide written notification to the Contracting Officer and COR immediately, and not later than four (4) hours, when an employee working on an HHS information system or with access to HHS information is reassigned or leaves the Contractor or subcontractor's employment on the cognizant HHS contract. The Contracting Officer and COR must also be notified immediately by the Contractor or subcontractor prior to an unfriendly termination.

(g) *Non-disclosure agreement*. The Contractor and subcontractors shall submit completed non-disclosure agreements, as provided by the Contracting Officer, for each employee having access to non-public government

information under this contract. The non-disclosure agreements shall be submitted to the Contracting Officer prior to the performance of work.

(h) *HHS information custodial requirements*.

(1) *Release, publication, and use of data*. Information made available to a Contractor or subcontractor by HHS for the performance or administration of a contract or information developed by the Contractor

/subcontractor in performance or administration of a contract shall be used only for the stated contract purpose and shall not be used in any other way without HHS prior written approval. This clause expressly limits the Contractor's/subcontractor's rights to use data as described in 52.227-14, Rights in Data—General, paragraph (d).

(2) *Media sanitization*. HHS information shall not be co-mingled with any other data on the Contractors /subcontractor's information systems or media storage systems in order to ensure federal and HHS requirements related to data protection, information segregation, classification requirements, and media sanitization can be met (see HHS Cybersecurity Program). HHS reserves the right to conduct scheduled or unscheduled on-site inspections, assessments, or audits of Contractor and subcontractor IT resources,
information systems and assets to ensure data security and privacy controls, separation of data and job duties, and destruction/media sanitization procedures are in compliance with Federal and HHS requirements. The Contractor and subcontractor will provide all necessary access and support to HHS and/or GAO staff during periodic control assessments or audits.

(3) *Data retention, destruction and contractor self-certification*. The Contactor and its subcontractors are responsible for collecting and destroying any HHS data provided, created, or stored under the terms of this contract, to a point where HHS data or materials are no longer readable or reconstructable to any degree, in accordance with NIST SP 800-88, *Guidelines for Media Sanitization*, or subsequent directive. Prior to termination or completion of this contract, the Contractor/subcontractor must provide its plan for destruction or return of all HHS data in its possession accordance with contract requirements or Contracting Officer instructions for disposition, including compliance with National Institute of Standards and Technology (NIST) SP 800-88, Guidelines for Media Sanitization, for the purposes of media sanitization on all IT equipment. The Contractor must certify in writing to the Contracting Officer within 30 days of termination of the contract that the data destruction requirements in this paragraph have been met.

(4) *Return of HHS data and information*. When information, data, documentary material, records and/or equipment is no longer required, it shall be returned to the HHS (as stipulated by the Contracting Officer or the COR) or the Contractor/subcontractor must hold it until otherwise directed. Items returned will be hand carried, securely mailed, emailed, or securely electronically transmitted to the Contracting Officer or to the address as provided in the contract or by the assigned COR, and/or accompanying business associate agreement. Depending on the method of return, Contractor/subcontractor must store, transport, or transmit HHS sensitive information, when permitted by the contract using HHS-approved encryption tools that are, at a minimum, validated under Federal Information Processing Standards (FIPS) 140-3 (or its successor). If mailed, Contractor/subcontractor must send via a trackable method (USPS, UPS, Federal Express, etc.) and immediately provide the Contracting Officer with the tracking information. No information, data, documentary material, records or equipment will be destroyed unless done in accordance with the terms of this contract and the HHS Agency Records Control Schedules (2019).

(5) *Use of HHS data and information*. The Contractor/subcontractor must receive, gather, store, back up, maintain, use, disclose and dispose of HHS information only in compliance with the terms of the contract and applicable Federal and HHS information confidentiality and security laws, regulations, and policies. If Federal or HHS information confidentiality and security laws, regulations, and policies become applicable to the HHS information or information systems after execution of the contract, or if the NIST issues or updates applicable FIPS or Special Publications (SP) after execution of this contract, the parties agree to negotiate in good faith to implement the information confidentiality and security laws, regulations and policies for this contract as a result of any updates, if required.

(6) *Copying HHS data or information*. The Contractor/subcontractor shall not make copies of HHS information except as authorized and necessary to perform the terms of the contract or to preserve electronic information stored

on Contractor/subcontractor electronic storage media for restoration in case any electronic equipment or data used by the Contractor/subcontractor needs to be restored to an operating state. If copies are made for restoration purposes, after the restoration is complete, the copies must be appropriately destroyed

(7) *Violation of information custodial requirements*. If HHS determines that the Contractor has violated any of HHS information confidentiality, privacy, or security provisions, it shall be sufficient grounds for HHS to withhold payment to the Contractor or third-party or terminate the contract for default in accordance with FAR part 49 or terminate for cause in accordance with FAR 12.403.

(8) *Encryption*. The Contractor/subcontractor must store, transport, or transmit HHS sensitive information, when permitted by the contract, using cryptography, HHS encryption policies, and HHS- approved encryption tools that are, at a minimum, validated under FIPS 140-3 (or its successor).

(9) *Firewall and web services security controls*. The Contractor/subcontractor's firewall and Web services security controls, if applicable, shall meet or exceed HHS minimum requirements. HHS Configuration Standards Guidelines are available upon request.

(10) *Disclosure of HHS data and information*. Except for uses and disclosures of HHS information authorized in a cognizant contract for performance of the contract, the Contractor/subcontractor may use and disclose HHS information only in two other situations: (i) subject to paragraph 10 of this section, in response to a court order from a court of competent jurisdiction, or (ii) with HHS prior written approval. The Contractor/subcontractor must refer all requests for, demands for production of, or inquiries about, HHS information and information systems to the Contracting Officer for response. If the Contractor/subcontractor is in receipt of a court order or other request or believes it has a legal requirement to disclose HHS information, that Contractor/subcontractor shall immediately refer such court order or other request to the Contracting Officer for response. If the Contractor or subcontractor discloses information on behalf of HHS, the Contractor and/or subcontractor must maintain an accounting of disclosures. Accounting of Disclosures documentation maintained by the Contractor/subcontractor will include the name of the individual to whom the information pertains, the date of each disclosure, the nature or description of the information disclosed, a brief statement of the purpose of each disclosure or, in lieu of such statement, a copy of a written request for a disclosure, and the name and address of the person or agency to whom the disclosure was made. The Contractor/subcontractor will provide its Accounting of Disclosures upon request and within 15 calendar days to the assigned COR and Privacy Officer. Accounting of disclosures should be provided electronically via encrypted email to the COR and designated HHS facility Privacy Officer as provided in the contract, business associate agreement, or by the Contracting Officer. If providing the Accounting of disclosures electronically cannot be done securely, the Contractor/subcontractor will provide copies via trackable methods (UPS, USPS, Federal Express, etc.) immediately, providing the designated COR and Privacy Officer with the tracking information.

(11) *Compliance with privacy statutes and applicable regulations*. The Contractor/subcontractor shall not disclose HHS information protected by any of HHS privacy statutes or applicable regulations including, but not limited to, the Privacy Act of 1974 or the HIPAA Rules. If the Contractor/subcontractor is in receipt of a court order or other requests for HHS information or has questions if it can disclose information protected under the above-mentioned confidentiality statutes because it is required by law, that Contractor/subcontractor shall immediately refer such court order or other request to the Contracting Officer for response.

(i) Compliance with identification policies. Contractors shall comply with the Homeland Security Presidential Directive (HSPD)-12, Policy for a Common Identification Standard for Federal Employees and Contractors; OMB M-05-24; OMB M-19-17; FIPS 201, Personal Identity Verification (PIV) of Federal Employees and Contractors; HHS HSPD-12 policy; HHS Policy for Information Security and Privacy Protection (IS2P) Control Catalog, and Executive Order 13467, Part 1, section 1.2.

(j) *Report of known or suspected incident or breach*. The Contractor, subcontractor, third-party affiliate or business associate, and its employees shall notify HHS immediately via the Contracting Officer and the COR or within one (1) hour of a known or suspected incident or breach. The initial notification may first be made verbally but must be followed up in writing within one (1) hour. Report all actual or suspected incident and breach information to the Contracting Officer and the COR as identified in the contract or as directed in the contract, within one hour of discovery or suspicion.

(1) Such issues shall be remediated as quickly as is practical, but in no event longer than *to be determined* days. The Contractor shall notify the Contracting Officer in writing.

(2) When the security fixes involve installing third party patched (e.g., Microsoft OS patches or Adobe Acrobat), the Contractor will provide written notice to HHS that the patch has been validated as not affecting the systems within 10 working days. When the Contractor is responsible for operations or maintenance of the systems, they shall apply the security fixes within *to be determined* days.

(3) All other vulnerabilities shall be remediated in a timely manner based on risk, in accordance with the timelines specified in the HHS Policy for Vulnerability Management, and the HHS Standard for Plan of Action and Milestones (POAM) Management and Reporting. Contractors shall notify the Contracting Officer, and COR within 2 business days after remediation of the identified vulnerability. Exceptions to this paragraph (e.g., for the convenience of HHS) must be requested by the Contractor through the COR and shall only be granted with approval of the Contracting Officer and the Office of the Chief Information Officer (OCIO). These exceptions will be tracked by the Contractor in concert with the Government in accordance with HHS Policy for IT Procurements–Security and Privacy Language.

(k) *Incident and breach investigation*.

(1) The Contractor/ subcontractor shall immediately notify the Contracting Officer and COR for the contract of any known or suspected incident or breach (see definitions, paragraph (a)), or any other unauthorized disclosure of sensitive information, including that contained in system(s) to which the Contractor/subcontractor has access.

(2) To the extent known by the Contractor/subcontractor, the Contractor/ subcontractor's notice to HHS shall identify the information involved, an estimate of the number of potentially impacted individuals, the circumstances surrounding the incident (including to whom, how, when, and where the HHS information or assets were placed at risk or compromised), and any other information that the Contractor/subcontractor considers relevant.

(3) With respect to unsecured protected health information, the business associate is deemed to have discovered an incident as defined above when the business associate either knew, or by exercising reasonable diligence should have been known to an employee of the business associate. Upon discovery, the business associate must notify HHS of the incident immediately within one hour of discovery or suspicion as agreed to in the business associate agreement.

(4) In instances of theft or break-in or other criminal activity, the Contractor/subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction. The Contractor, its employees, and its subcontractors and their employees shall cooperate with HHS and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/subcontractor shall cooperate with HHS in any civil litigation to recover HHS information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.

(l) *Incident and breach notification requirements*.

(1) The Contractor/subcontractor shall provide notice to HHS of an incident as set forth in the incident and breach investigation section of this clause. The Contractor shall fully cooperate with HHS or third-party entity performing an independent risk analysis on behalf of HHS. Failure to cooperate may be deemed a material incident or breach and grounds for contract termination.

(2) The Contractor/subcontractor shall fully cooperate with the HHS Computer Security Incident Response Center (CSIRC), HHS Breach Response Team, Operating Divisions (OPDIVs), Staff Divisions (STAFFDIVs), other stakeholders or any Government agency conducting an analysis regarding any notice of an incident or breach, potential incident or breach, or incident which may require the Contractor to provide information to the Government or third-party performing a risk analysis for HHS, and shall address all relevant information concerning the incident or breach, including the following:

(i) Nature of the event (loss, theft, unauthorized access).

(ii) Description of the event, including:

(A) Date of occurrence.

(B) Date of incident or breach detection.
(C) Data elements involved, including any PII, such as full name, social security number, date of birth, home address, account number, disability code.

(D) Number of individuals affected or potentially affected.

(E) Names of individuals or groups affected or potentially affected.

(F) Ease of logical data access to the lost, stolen or improperly accessed data in light of the degree of protection for the data, e.g., unencrypted, plain text.

(G) Amount of time the data has been out of HHS control.

(H) The likelihood that the sensitive information will or has been compromised (made accessible to and usable by unauthorized persons).

(I) Known misuses of data containing sensitive information, if any.

(J) Assessment of the potential harm to the affected individuals.

(K) Incident or breach analysis as outlined in the HHS Breach Response Policy and Plan, as appropriate.

(L) Whether credit protection services may assist record subjects in avoiding or mitigating the results of identity theft based on the sensitive information that may have been compromised.

(M) Steps taken in response to mitigate or prevent a repetition of the incident.

(m) *Training*.

(1) All Contractor employees and subcontractor employees requiring access to HHS information or HHS information systems shall complete the following before being granted access to HHS information and its systems:

(i) On an annual basis, successfully complete the HHS Privacy and Information Security Awareness and HHS Information Security Rules of Behavior training.

(ii) On an annual basis, sign and acknowledge (either manually or electronically) understanding of and responsibilities for compliance with the HHS Information Security Rules of Behavior, relating to access to HHS information and information systems.

(iii) Successfully complete any additional cyber security or privacy training, as required for HHS personnel with equivalent information system access.

(2) The Contractor shall provide to the Contracting Officer and/or the COR a copy of the training certificates and affirmation that HHS Information Security Rules of Behavior signed by each applicable employee have been completed and submitted within five (5) days of the initiation of the contract and annually thereafter, as required.

(3) Failure to complete the mandatory annual training and acknowledgement of the HHS Information Security Rules of Behavior, within the timeframe required, is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the training and documents are complete.

(n) *Subcontract flow down*. The Contractor shall include the substance of this clause, including this paragraph (k), in subcontracts, third-party agreements, and business associate agreements, of any amount and in which subcontractor employees, third-party servicers/employees, and business associates will perform functions where they will have access to HHS information (including HHS sensitive information), information systems, information technology (IT) or providing and accessing information technology-related contract services, support services, and related resources (see HHSAR 302.101 definition of information technology-related contracts.)

(End of clause)

HHSAR 352.204-72 Records Management (FEB 2024)(DEVIATION)

(a) Applicability. This clause applies to contracts that include Federal records, as defined in paragraph (b).

(b) *Definition*. As used in this clause—
Federal record means all recorded information, regardless of form or characteristics, made or received by a Federal agency under Federal law or in connection with the transaction of public business and preserved or appropriate for preservation by that agency or its legitimate successor as evidence of the organization, functions, policies, decisions, procedures, operations, or other activities of the United States Government
or because of the informational value of data in them.

See 44 U.S.C. 3301. (1) The term Federal record—

(i) Includes HHS records;

(ii) Does not include personal materials;

(iii) Applies to records created, received, or maintained by Contractors pursuant to their contract; and

(iv) May include deliverables and documentation associated with deliverables.

(2) *Recorded information* means all traditional forms of records, regardless of physical form or characteristics, including information created, manipulated, communicated, or stored in digital or electronic form. (See 44 U.S.C. 3301.)

(3) *Personal materials* means documentary materials belonging to an individual that are not used to conduct agency business. Personal files are excluded from the definition of Federal records and are not owned by the Government. (See 36 CFR 1220.18.)

(c) *Requirements.*

(1) The Contractor shall comply with all applicable records management laws and regulations, as well as National Archives and Records Administration (NARA) records policies, including but not limited to the Federal Records Act (44 U.S.C. chapters 21, 29, 31, 33), NARA regulations at 36 CFR chapter XII subchapter B, and those policies associated with the safeguarding of records covered by the Privacy Act of 1974 (5 U.S.C. 552a). These policies include the preservation of all Federal records, regardless of form or characteristics, mode of transmission, or state of completion.

(2) In accordance with 36 CFR 1222.32, all data created for Government use and delivered to, or falling under the legal control of, the Government are Federal records subject to the provisions of 44 U.S.C. chapters 21, 29, 31, and 33, the Freedom of Information Act (FOIA) (5 U.S.C. 552), and the Privacy Act of 1974 (5 U.S.C. 552a), and must be managed and scheduled for disposition only as permitted by statute or regulation.

(3) In accordance with 36 CFR 1222.32, the Contractor shall maintain all Federal records created for Government use or created in the course of performing the contract and/or delivered to, or under the legal control of the Government and must be managed in accordance with Federal law. Electronic records and associated metadata must be accompanied by sufficient technical documentation to permit understanding and use of the records and data.

(4) The Contractor is responsible for preventing the alienation or unauthorized destruction of Federal records, including all forms of mutilation. Federal records may not be removed from the legal custody of HHS or destroyed except for in accordance with the provisions of the agency records schedules and with the written concurrence of the Contracting Officer. Willful and unlawful destruction, damage or alienation of Federal records is subject to the fines and penalties imposed by 18 U.S.C. 2701. The Contractor shall report to the Contracting Officer any unlawful or accidental removal, defacing, alteration, or destruction of Federal records.

(5) The Contractor shall immediately notify the Contracting Officer upon discovery of any inadvertent or unauthorized disclosures of information, data, documentary materials, records or equipment. Disclosure of non-public information is limited to authorized personnel with a need-to-know as described in the contract. The Contractor shall ensure that appropriate personnel are trained to adhere to these contract requirements, and that applicable, administrative, technical, and physical safeguards are established to ensure the security and confidentiality of information, data, documentary material, Federal records and/or equipment is properly protected. The Contractor shall not remove Federal Records from Government facilities or systems, or facilities or systems operated or maintained on the Government's behalf, without the express written permission of the Contracting Officer. When information, data, documentary material, Federal records and/or equipment are no longer required, it shall be returned to HHS control, or the
Contractor must hold it until otherwise directed. Items returned to the Government shall be hand carried, mailed, emailed, or securely electronically transmitted to the Contracting Officer or as otherwise directed by the Contracting Officer. Destruction of Federal records is expressly prohibited unless in accordance with paragraph (c)(4).

(6) The Contractor shall only use Government information technology equipment for purposes specifically authorized by the contract and in accordance with HHS policy.

(7) The Contractor shall not create or maintain any Federal records containing any non-public HHS information that are not specifically authorized by the contract.

(8) The Contractor shall not retain, use, sell, or disseminate copies of any deliverable that
contains information covered by the Privacy Act of 1974 or that which is generally protected from public disclosure by an exemption to the Freedom of Information Act.

(9) All Contractor employees assigned to this contract handle Federal records are required to take HHS provided records management training. The Contractor is responsible for confirming training has been completed according to agency policies, including initial training and any annual or refresher training.

(d) *Subcontract flow down.* The Contractor shall incorporate the substance of this clause, its terms and requirements including this paragraph, in all subcontracts under this contract.

(END OF CLAUSE)

HHSAR 352.208-70 Printing and Duplication (FEB 2026) (DEVIATION)

(a) Unless otherwise specified in this contract, no printing by the Contractor or any subcontractor is authorized under this contract. All printing required must be performed by the Government Printing Office except as authorized by the Contracting Officer. The Contractor shall submit camera-ready copies to the Contracting Officer's Representative (COR). The terms "printing" and "duplicating/copying" are defined in the Government Printing and Binding Regulations of the Joint Committee on Printing.
(b) If necessary for performance of the contract, the Contractor may duplicate or copy less than 5,000 production units of only one page, or less than 25,000 production units in aggregate of multiple pages for the use of a department or agency. A production unit is defined as one sheet, size 8.5 x 11 inches, one side only, and one color. The pages may not exceed a maximum image size of 10¾ by 14¼ inches. This page limit applies to each printing requirement and not for all printing requirements under the entire contract.
(c) Approval for all printing, as well as duplicating/copying in excess of the stated limits, shall be obtained from the COR who will consult with the designated publishing services office and provide direction to the contractor. The cost of any unauthorized printing or duplicating/copying under this contract will be considered an unallowable cost for which the Contractor will not be reimbursed.

HHSAR 352.232-71 Electronic Submission of Payment Requests (Feb 2022)

(a) Definitions. As used in this clause—

(1) " Payment request" means a bill, voucher, invoice, or request for contract financing payment with associated supporting documentation. The payment request must comply with the requirements identified in FAR 32.905(b), "Content of Invoices" and the applicable Payment clause included in this contract.

(b) Except as provided in paragraph (c) of this clause, the Contractor shall submit payment requests electronically using the Department of Treasury Invoice Processing Platform (IPP) or successor system. Information regarding IPP, including IPP Customer Support contact information, is available at www.ipp.gov or any successor site.

(c) The Contractor may submit payment requests using other than IPP only when the Contracting Officer authorizes alternate procedures in writing in accordance with HHS procedures.

(d) If alternate payment procedures are authorized, the Contractor shall include a copy of the Contracting Officer's written authorization with each payment request.

(END OF CLAUSE)

HHSAR 352.237-75 Key Personnel (DEC 2015)

The key personnel specified in this contract are considered to be essential to work performance. At least 30 days prior to the contractor voluntarily diverting any of the specified individuals to other programs or contracts the Contractor shall notify the Contracting Officer and shall submit a justification for the diversion or replacement and a request to replace the individual. The request must identify the proposed replacement and provide an explanation of how the replacement's skills, experience, and credentials meet or exceed the requirements of the contract (including, when applicable, Human Subjects Testing requirements). If the employee of the contractor is terminated for cause or separates from the contractor voluntarily with less than thirty days notice, the Contractor shall provide the maximum notice practicable under the circumstances. The Contractor shall not divert, replace, or announce any such change to key personnel without the written consent of the Contracting Officer. The contract will be modified to add or delete key personnel as necessary to reflect the agreement of the parties.

(End of clause)

HHSAR 352.239-70 Standards for Health Information Technology (DEC 2022)(DEVIATION)

(a) *Definitions.* As used in this clause—
Health information technology (health IT) means hardware, software, integrated technologies or related licenses, intellectual property, upgrades, or packaged solutions sold as services that are designed for or support the use by health care entities or patients for the electronic creation, maintenance, access, or exchange of health information. (42 U.S.C. 300jj)
Individually identifiable health information means information that is a subset of health information, including demographic information collected from an individual, and:
(1) Is created or received by a health care provider, health plan, employer, or health care clearinghouse; and (2) Relates to the past, present, or future physical or mental health condition of an individual; the provision of health care to an individual; or the past, present, or future payment for the provision of health care to an individual; and
(i) That identifies the individual; or
(ii) With respect to which there is a reasonable basis to believe the information can be used to identify the individual. (42 U.S.C. 300jj, 1320d)
ONC Health Information Technology Certification Program means the certification program administered by the HHS Office of the National Coordinator for Health Information Technology (ONC) using a third-party conformity assessment program for health IT. Certification criteria for the Program, which incorporate standards and implementation specifications in 45 CFR part 170 subpart B, are found in 45 CFR part 170, subpart C.
(b) Pursuant to the Health Information Technology for Economic and Clinical Health Act (HITECH Act), Pub. L. 111-5, Title XIII, sections 13111 and 13112, by submission of an offer and execution of a contract, the Contractor agrees that—

(1) For any work performed under the contract that involves implementing, acquiring, or upgrading health IT used for the direct exchange of individually identifiable health information between agencies and with non-Federal entities, the Contractor will utilize health IT that—
(i) Meets standards and implementation specifications adopted in 45 CFR part 170, subpart B, if such standards and implementation specifications can support the work performed under the contract; and
(ii) Is certified under the ONC Health Information Technology Certification Program, if certified technology can support the work performed under the contract (see certification criteria in 45 CFR part 170, subpart C), when the Contractor is an eligible professional in an ambulatory setting, or a hospital, eligible under sections 4101, 4102 and 4201 of the HITECH Act, or when the Contractor is implementing, acquiring or upgrading technology to be used by an eligible professional in an ambulatory setting, or a hospital, eligible under sections 4101, 4102 and 4201 of the HITECH Act.
(2) If the Contractor is a health care provider, health plan, or health insurance issuer, or is establishing an agreement with a health care provider, health plan, or health insurance issuer, for work performed under the contract that involves implementing, acquiring, or upgrading health IT, the Contractor will utilize health IT that—
(i) Meets standards and implementation specifications adopted in 45 CFR part 170, subpart B, if such standards and implementation specifications can support the work performed under the contract; and
(ii) Is certified under the ONC Health Information Technology Certification Program, if certified technology can support the work performed under the contract (see certification criteria in 45 CFR part 170, subpart C), when the Contractor is an eligible professional in an ambulatory setting, or a hospital, eligible under sections 4101, 4102 and 4201 of the HITECH Act, or when the Contractor is implementing, acquiring or upgrading technology to be used by an eligible professional in an ambulatory setting, or a hospital, eligible under sections 4101, 4102 and 4201 of the HITECH Act.
(c) If standards and implementation specifications adopted in 45 CFR part 170, subpart B, cannot support the work as specified in the contract, the Contractor is encouraged to use health IT that meets non-proprietary standards and implementation specifications developed by consensus-based standards development organizations. This may include standards identified in the ONC Interoperability Standards Advisory, available at https://www.healthit.gov/isa/.

(End of clause)

HHSAR 352.239-71 Security Requirements for Information Technology Resources (FEB 2024)(DEVIATION)

(a) *Definitions*. As used in this clause—
Information technology has the same meaning in FAR 2.101.
Information and communication technology (ICT) also means information technology (see FAR 2.101 for definitions).
Information system security plan means a formal document that provides an overview of the security requirements for an information system or an information security program and describes the security controls in place or planned for meeting those requirements.

(b) *Responsibilities*. The Contractor shall be responsible for information technology security for all systems connected to a Department of Health and Human Services (HHS) network or operated by the Contractor for HHS, regardless of location. This clause is applicable to all or any part of the contract that includes information technology resources or services in which the Contractor has physical or other system access to HHS information that directly supports the mission of HHS. Examples of tasks that require security provisions include—

(1) Hosting of HHS e-Government sites or other information technology operations;

(2) Acquisition, transmission, or analysis of data owned by HHS with significant replacement cost should the contractor's copy be corrupted; and

(3) Access to HHS general support systems/major applications at a level beyond that granted the general public, e.g., bypassing a firewall.

(c) *Information system security plan*. The Contractor shall develop, provide, implement, and maintain an Information System Security Plan. HHS information system and platform information technology systems must have a security plan that provides an overview of the security requirements for the system and describes the security controls in place or the plan for meeting those requirements. Generally, this plan shall describe the processes and procedures that the Contractor will follow to ensure appropriate security of information system resources developed, processed, or used under this contract. The security plan should include implementation status, responsible entities, resources, and estimated completion dates. Security plans may also include, but are not limited to, a compiled list of system characteristics or qualities required for system registration, and key security-related documents such as a risk assessment, privacy impact assessment (PIA), system interconnection agreements, contingency plan, security configurations, configuration management plan, incident response plan, and the system privacy plan, as determined by the Contracting Officer's Representative. The plan shall address the specific contract requirements regarding information systems or related support or services included in the contract, to include the PWS or SOW. The Contractor's Information System Security Plan shall comply with applicable Federal Laws that include, but are not limited to, 40 U.S.C. 11331, the Federal Information Security Modernization Act (FISMA) of 2014 and the E-Government Act of 2002. The plan shall meet information technology security requirements in accordance with Federal and HHS policies and procedures, and as amended during the term of this contract, and include, but are not limited to the following:

(1) OMB Circular A-130, Managing Information as a Strategic Resource;

(2) National Institute of Standards and Technology (NIST) Guidelines;

(3) Federal Information Processing Standard (FIPS) 200; and

(4) HHS Cybersecurity Program related to HHS information (including HHS sensitive information and information systems security and privacy), as well as those set forth in the contract specifications, statement of work, or performance work statement. These include, but are not limited to, the Cyber Security Checklist and Cyber Security Infographic at https://www.hhs.gov/hipaa/for- professionals/security/guidance/cybersecurity/index.html, which provides HHS procedures, responsibilities, and processes for complying with current Federal law, Executive Orders, policies, regulations, standards and guidance for protecting HHS information, information systems (see 302.101, Definitions), information technology, and ICT, security and privacy, and adhering to personnel security requirements when accessing HHS information or information systems.

(d) *Submittal of plan*. Within 60 days after contract award, the Contractor shall submit the Information System Security Plan to the Contracting Officer for review and approval.
(e) *Authority to Operate (ATO)*. As required by current HHS policy, the Contractor shall submit written proof of information technology security accreditation with a valid ATO to the Contracting Officer. Such written proof may be furnished either by the Contractor or by a third party. Accreditation shall be in accordance with HHS policy available from the Contracting Officer upon request. The Contractor shall submit for acceptance by the Contracting Officer along with this ATO a final security plan, risk assessment, security test and evaluation, privacy threshold analysis or privacy impact assessment, and a disaster recovery plan/continuity of operations plan.

(f) *Annual validation*. On an annual basis, the Contractor shall verify in writing to the Contracting Officer that the IT Security Plan remains valid.

(g) *Banners*. The Contractor shall ensure that the official HHS banners are displayed on all HHS systems (both public and private) operated by the Contractor that contain Privacy Act or other sensitive information before allowing anyone access to the system. The Office of Information Technology will make official HHS banners available to the Contractor.

(h) *Screening and access*. The Contractor shall screen all personnel requiring privileged access or limited privileged access to systems operated by the Contractor for HHS or interconnected to an HHS network in accordance with HHS policies referenced in paragraph (c).

(i) *Training*. The Contractor shall ensure that its employees performing services under this contract complete HHS security awareness and privacy training on an annual basis. This includes signing an acknowledgment on an annual basis that they have read, understand, and agree to abide by the HHS Rules of Behavior for the Use of HHS Information and IT Resources Policy as required; FAR 39.105, Privacy; clause 352.204-71, Information and Information Systems Security, and this clause.

(j) *Government access*. The Contractor shall provide the Government access to the Contractor's and subcontractors' facilities, installations, operations, documentation, information systems, databases, and personnel used in performance of the contract. The Contractor shall provide access to enable a program of information technology inspection (to include vulnerability testing), investigation and audit (to safeguard against threats and hazards to the integrity, availability and confidentiality of HHS data or to the function of information technology systems operated on behalf of HHS), and to preserve evidence of computer crime.

(k) *Notification of termination of employees*. The Contractor shall immediately notify the Contracting Officer when an employee who has access to HHS information systems or data terminates employment.

(l) *Subcontract flow down requirement*. The Contractor shall incorporate and flow down the substance of this clause to all subcontracts that meet the conditions in paragraph (a) of this clause.

(END OF CLAUSE)

HHSAR 352.239-75, Security Controls Compliance Testing (FEB 2024)(DEVIATION)

On a periodic basis, HHS, including the Office of Inspector General, reserves the right to evaluate any or all of the security controls and privacy controls implemented by the Contractor under the clauses contained within the contract. With 10 working-days' notice, at the request of the government, the Contractor must fully cooperate and assist in a government-sponsored security controls assessment at each location wherein HHS information is processed or stored, or information systems are developed, operated, maintained, or used on behalf of HHS, including those initiated by the Office of Inspector General. The government may conduct a security control assessment on shorter notice, to include unannounced assessments, as determined by HHS in the event of an incident or a breach, or at any other time.

(END OF CLAUSE)

HHSAR 352.239-79, Information System Hosting, Operation, Maintenance, or Use (FEB 2024)(DEVIATION)

(a) Definitions. As used in this clause—

Assessment and Authorization (A&A) means the process used to ensure information systems including Major Applications and General Support Systems have effective security safeguards which have been implemented, planned for, and documented in an Information Technology Security Plan. The A&A process per applicable HHS policies and procedures is the mechanism by which HHS provides an Authorization to Operate (ATO), the official management decision given by the HHS to authorize operation of an information system.

Information system security plan means a formal document that provides an overview of the security requirements for an information system or an information security program and describes the security controls in place or planned for meeting those requirements.

(b) *Hosting, operation, maintenance, or use at non-HHS facilities.* For information systems that are hosted, operated, maintained, or used on behalf of HHS at non-HHS facilities, Contractors/subcontractors are fully responsible and accountable for ensuring compliance with all applicable Health Insurance Portability and Accountability (HIPAA) Act of 1996 (HIPAA) regulations, the Privacy Act and other required HHS confidentiality statutes included in HHS mandatory yearly training and privacy policy, Federal Information Security Modernization Act (FISMA), National Institutes of Standards and Technology (NIST), Federal Information Processing Standards (FIPS), and HHS security and privacy policy. This includes conducting compliant risk assessments, routine vulnerability scanning, system patching and change management procedures, and the completion of an acceptable contingency plan for each system. The Contractor's security and privacy control procedures must be equivalent to or exceed, those procedures used to secure HHS systems. A Privacy Impact Assessment (PIA) (if the system includes Personally Identifiable Information (PII)) or a Privacy Threshold Analysis (to determine if the system includes PII)

must also be provided to the Contracting Officer Representative (COR) and approved by HHS Senior Agency Official for Privacy (SAOP) or designee prior to ATO. All external Internet connections to HHS network involving HHS information must be in accordance with the Trusted Internet Connections (TIC) Reference Architecture and reviewed and approved by HHS prior to implementation. For Cloud Services hosting, the Contractor shall also ensure compliance with the Federal Risk and Authorization Management Program (FedRAMP).

(c) *Collecting, processing, transmitting, and storing of PII.* Adequate security and privacy controls for collecting, processing, transmitting, and storing of PII, as determined by the HHS SAOP or designee, must be in place, tested, and approved by HHS prior to hosting, operation, maintenance, or use of the information system, or systems by or on behalf of HHS. These security and privacy controls are to be assessed and stated within the PIA, Information System Security Plan, Information System Privacy Plan, Security Control Assessment Report, and/or Privacy Control Assessment Report, as agreed upon by the Contractor, COR, and the Operating Division Senior Official for Privacy. If these controls are determined not to be in place, or inadequate, a Plan of Action and Milestones (POA&M) must be submitted and approved prior to the collection of PII.

(d) *Annual FISMA security controls assessment.* The Contractor/subcontractor's system must adhere to all FISMA, FIPS, and NIST standards related to the annual FISMA security controls assessment and review and update the PIA. Any deficiencies noted during this assessment must be provided to the Contracting Officer for entry into HHS Plan of Action & Milestones (POA&M) management process. The Contractor/subcontractor must use HHS POA&M process to document planned remedial actions to address any deficiencies in information security policies, procedures, and practices, and the completion of those activities. Security deficiencies must be corrected within the timeframes specified by the HHS in the performance work statement or statement of work, or in the approved remediation plan through the HHS POA&M process. Contractor/subcontractor procedures are subject to periodic, unannounced assessments by HHS officials, including the HHS Office of Inspector General. The physical security aspects associated with Contractor/subcontractor activities must also be subject to such assessments. The results of an annual review or a major change in the cybersecurity posture at any time may indicate the need for reassessment and reauthorization of the system. If major changes to the system occur that may affect the privacy or security of the data or the system, the A&A of the system may need to be reviewed, retested and re-authorized per HHS Rules of Behavior for the Use of HHS Information and IT Resources Policy. Major changes introducing new privacy risks require an updated and reapproved PIA.

(e) *Annual self-assessment.* The Contractor/subcontractor must conduct an annual self-assessment on all systems and outsourced services as required. Both hard copy and electronic copies of the assessment must be provided to the COR. HHS reserves the right to conduct such an assessment using government personnel or another Contractor/subcontractor. The Contractor/subcontractor must take appropriate and timely action, as may be specifically addressed in the contract, to correct or mitigate any weaknesses discovered during such testing at no additional cost to the Government to correct Contractor/subcontractor systems and outsourced services.

(f) *Prohibition of installation and use of personally-owned or Contractor-owned equipment or software on HHS networks.* HHS prohibits the installation and use of personally-owned or Contractor/subcontractor-owned equipment or software on HHS networks. If non-HHS owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, performance work statement, statement of work, or contract. All of the security controls required for government furnished equipment must also be utilized in approved other equipment (OE) at the Contractor’s expense. All remote systems must be equipped with, and use, an HHS-approved antivirus software and a personal (host-based or enclave based) firewall that is configured with an HHS-approved configuration. Software must be kept current, including all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-viral software and the firewall on the non-HHS owned OE.

(g) *Disposal or return of electronic storage media on non-HHS leased or non-HHS owned IT equipment.* All electronic storage media used on non-HHS leased or non-HHS owned IT equipment that is used to store, process, or access HHS information must be handled in adherence with disposition instructions upon—

(1) Completion or termination of the contract; or

(2) Disposal or return of the IT equipment by the Contractor/subcontractor or any person acting on behalf of the Contractor/subcontractor, whichever is earlier. Media (e.g., hard drives, optical disks, CDs, back-up tapes) used by the Contractors/ subcontractors that contain HHS information must be returned to the HHS for sanitization or destruction or the Contractor/subcontractor must self-certify that the media has been disposed of per disposition instructions. This must be completed within 30 days of termination of the contract.

(h) *Bio-Medical devices and other equipment or systems.* Bio-Medical devices and other equipment or systems containing media (e.g., hard drives, optical disks) with HHS sensitive information will not be returned to the Contractor at the end of lease, for trade-in, or other purposes. For purposes of these devices and protection of HHS sensitive information the devices may be provided back to the Contractor under one of three scenarios—

(1) The Contractor must accept the system without the drive;
(2) A spare drive must be installed in place of the original drive at time of turn-in if HHS initial medical device purchase included a spare drive; or
(3) The Contractor may request reimbursement for the drive at a reasonable open market replacement cost to be separately negotiated by the Contracting Officer and the Contractor at time of contract closeout.

(END OF CLAUSE)

CDCG.02 Contracting Officer's Representative (COR) (Jul 2017)
Performance of the work hereunder shall be subject to the technical directions of the designated COR for this contract.

As used herein, technical directions are directions to the Contractor which fill in details, suggests possible lines of inquiry, or otherwise completes the general scope of work set forth herein. These technical directions must be within the general scope of work and may not alter the scope of work or cause changes of such a nature as to justify an adjustment in the stated contract price/cost, or any stated limitation thereof.

In the event that the Contractor believes full implementation of any of these directions may exceed the scope of the contract, he or she shall notify the originator of the technical direction and the Contracting Officer, imme352diately or as soon as possible, in a letter or e-mail separate of any required report(s). No technical direction, nor its fulfillment, shall alter or abrogate the rights and obligations fixed in this contract.

The Government COR is not authorized to change any of the terms and conditions of this contract. Contract changes shall be made only by the Contracting Officer through properly written modification(s) to the contract.

The Government will provide the Contractor with a copy of the COR delegation memorandum upon request.

CDCG.03 Contracting Officer (Jul 1999)
(a) The Contracting Officer is the only individual who can legally commit the Government to the expenditure of public funds. No person other than the Contracting Officer can make any changes to the terms, conditions, general provisions, or other stipulations of this contract.

(b) No information, other than that contained in an authorized modification to this contract, duly issued by the Contracting Officer, received from any person employed by the United States Government, or otherwise, shall be considered grounds for deviation from any stipulation of this contract.

CDCG.07 Payment by Electronic Funds Transfer (Feb 2018)
(a) The Government shall use electronic funds transfer to the maximum extent possible when making payments under this contract. FAR 52.232-33, Payment by Electronic Funds Transfer –System for Award Management, requires the contractor to designate in writing a financial institution for receipt of electronic funds transfer payments.

(b) In the case that EFT information is not within the System of Award Management, FAR 52.232-34 requires mandatory submission of Contractor's EFT information directly to the office designated in this contract to receive that information (hereafter: "designated office"); see below. The contractor shall submit the EFT information within the form titled "ACH Vendor/Miscellaneous Payment Enrollment Form" to the address indicated below. Note: The form is either attached to this contract (see Section J, List of Attachments) or may be obtained by contacting the Contracting Officer or the CDC Office of Financial Resources at 678-475-4510.

(c) In cases where the contractor has previously provided such information, i.e., pursuant to a prior contract/order, and been enrolled in the program, the form is not required unless the designated financial institution has changed.

(d) The completed form shall be mailed or sent via facsimile after award, but no later than 14 calendar days before an invoice is submitted, to the following address:

The Centers for Disease Control and Prevention Office of Financial Resources (OFR)

P.O. Box 15580 Atlanta, GA 30333
Or – Fax copy to: 404-638-5342

CDCH.04 Key Personnel (Jan 2021)
The key personnel cited below are considered essential to the work performed under the contract. Pursuant to the terms of HHSAR Clause 352.237-75, Key Personnel, the Contractor shall not replace or divert any of these individuals without the written consent of the Contracting Officer.

Personnel	Title
	Web Developer Lead
	Web Developer
	Web Developer

(END OF CLAUSE)

CDCH.08 Smoke Free Working Environment (May 2009)
In compliance with Department of Health and Human Services (DHHS) regulations, all contractor personnel performing work within CDC/ATSDR facilities shall observe the CDC/ATSDR smoke-free working environment policy at all times. This policy prohibits smoking in all CDC/ATSDR buildings and in front of buildings which are open to the public. This policy is also applicable to contractor personnel who do not work full-time within CDC/ATSDR facilities, but are attending meetings within CDC/ATSDR facilities.

(END OF CLAUSE)

CDCH.13 Government Property (Jul 2017)
(a) Government-Furnished Property (GFP). In accordance with the terms of FAR 52.245-1, Government Property, the Government reserves the right to supply the Contractor, as Government-furnished property, any additional supplies, equipment, and materials determined by the Contracting Officer to be necessary and in the best interest of the Government.

(b) Contractor-Acquired Property (CAP). The Contractor must receive written consent from the Contracting Officer prior to purchase of any CAP not expressly identified in the contract, and as defined in FAR 52.245-1.

(c) Accountable and Sensitive Government Property. The Government will provide property labels and other identification for contractor-acquired Government property that is considered Accountable as defined in the HHS Logistics Management Manual (LMM) or considered Sensitive as defined in CDC's Sensitive Items List (http://intranet.cdc.gov/ofr/documents/contracts/Authorized-Prohibited-List.pdf)

(d) The contractor shall be responsible for the control and accountable record keeping of any Government property used in the performance of this contract predominately outside the confines of a Government controlled workspace in accordance with the HHS Contracting Guide found on the OSSAM Government Property and Contractors Property intranet page.

(e) The Chief of the Office of Safety, Security and Asset Management (OSSAM), Asset Management Services Office, Centers for Disease Control and Prevention (CDC), is hereby designated as the Property Administrator for this contract. The Contractor shall identify each item of equipment furnished by the Government to the Contractor or acquired by the Contractor using contract funds, with a suitable decal, tag, or other marking, as prescribed by the Property Administrator, and shall follow the guidance set forth in the HHS Contracting Guide.

(END OF CLAUSE)

CDCH.14 Records Management Obligations (Jun 2020)

A. Applicability

The following applies to all Contractors whose employees create, work with, or otherwise handle Federal records, as defined in Section B, regardless of the medium in which the record exists.

B. Definitions

"Federal record" as defined in 44 U.S.C. § 3301, includes all recorded information, regardless of form or characteristics, made or received by a Federal agency under Federal law or in connection with the transaction of public business and preserved or appropriate for preservation by that agency or its legitimate successor as evidence of the organization, functions, policies, decisions, procedures, operations, or other activities of the United States Government or because of the informational value of data in them.

The term Federal record:

1. includes Centers for Disease Control and Prevention (CDC) records.
2. does not include personal materials.
3. applies to records created, received, or maintained by Contractors pursuant to their CDC contract.
4. may include deliverables and documentation associated with deliverables.

C. Requirements

1. Contractor shall comply with all applicable records management laws and regulations, as well as National Archives and Records Administration (NARA) records policies, including but not limited to the Federal Records Act (44 U.S.C. chapter. 21, 29, 31, 33), NARA regulations at 36 CFR Chapter XII Subchapter B, and those policies associated with the safeguarding of records covered by the Privacy Act of 1974 (5 U.S.C. 552a). These policies include the preservation of all records, regardless of form or characteristics, mode of transmission, or state of completion.

2. In accordance with 36 CFR 1222.32, all data created for Government use and delivered to, or falling under the legal control of, the Government are Federal records subject to the provisions of 44 U.S.C. chapters 21, 29, 31, and 33, the Freedom of Information Act (FOIA) (5 U.S.C. 552), as amended, and the Privacy Act of 1974 (5 U.S.C. 552a), as amended and must be managed and scheduled for disposition only as permitted by statute or regulation.

3. In accordance with 36 CFR 1222.32, Contractor shall maintain all records created for Government use or created in the course of performing the contract and/or delivered to, or under the legal control of the Government and must be managed in accordance with Federal law. Electronic records and associated metadata must be accompanied by sufficient technical documentation to permit understanding and use of the records and data.

4. CDC and its contractors are responsible for preventing the alienation or unauthorized destruction of records, including all forms of mutilation. Records may not be removed from the legal custody of CDC or destroyed except for in accordance with the provisions of the agency records schedules and with the written concurrence of the Head of the Contracting Activity. Willful and unlawful destruction, damage or alienation of Federal records is subject to the fines and penalties imposed by 18 U.S.C. 2701. In the event of any unlawful or accidental removal, defacing, alteration, or destruction of records, Contractor must report to the Contracting Officer and the Contracting Officer's Representative. The agency must report promptly to NARA in accordance with 36 CFR 1230.

5. The Contractor shall immediately notify the appropriate Contracting Officer upon discovery of any inadvertent or unauthorized disclosures of information, data, documentary materials, records or equipment. Disclosure of non-public information is limited to authorized personnel with a need-to-know as described in the contract. The Contractor shall ensure that the appropriate personnel, administrative, technical, and physical safeguards are established to ensure the security and confidentiality of this information, data, documentary material, records and/or equipment is properly protected. The Contractor shall not remove material from Government facilities or systems, or facilities or systems operated or maintained on the Government's behalf, without the express written permission of the Head of the Contracting Activity. When information, data, documentary material, records and/or equipment is no longer required, it shall be returned to CDC control, or the Contractor must hold it until otherwise directed. Items returned to the Government shall be hand carried, mailed, emailed, or securely electronically transmitted to the Contracting Officer or address prescribed in the contract. Destruction of records is EXPRESSLY PROHIBITED unless in accordance with Paragraph (4).

6. The Contractor is required to obtain the Contracting Officer's approval prior to engaging in any contractual relationship (sub-contractor) in support of this contract requiring the disclosure of information, documentary material and/or records generated under, or relating to, contracts. The Contractor (and any sub-contractor) is required to abide by Government and CDC guidance for protecting sensitive, proprietary information, classified, and controlled unclassified information.

7. The Contractor shall only use Government IT equipment for purposes specifically tied to or authorized by the contract and in accordance with CDC policy.

8. The Contractor shall not create or maintain any records containing any non-public CDC information that are not specifically tied to or authorized by the contract.

9. The Contractor shall not retain, use, sell, or disseminate copies of any deliverable that contains information covered by the Privacy Act of 1974 or that which is generally protected from public disclosure by an exemption to the Freedom of Information Act.

10. Training. All Contractor employees assigned to this contract who create, work with, or otherwise handle records are required to take CDC-provided records management training. The Contractor is responsible for confirming training has been completed according to agency policies, including initial training and any annual or refresher training.

D. Flow down of requirements to subcontractors

1. The Contractor shall incorporate the entire substance of the terms and conditions herein, including this paragraph, in all subcontracts under this contract, and must require written subcontractor acknowledgment of same.

2. Violation by a subcontractor of any provision set forth herein will be attributed to the Contractor.

(END OF CLAUSE)

CDCH.16 Non-Disclosure Agreement for Contractor and Contractor Employees (Jun 2020)
(a) The contractor and contractor employees shall prepare and submit Non-Disclosure Agreements (NDA) to the Contracting Officer prior to access of government information or the commencement of work at CDC.

(b) The NDAs, at Exhibit I and II, are required in service contracts where contractor’s employees will have access to non-public and procurement-sensitive information while performing functions in support of the Government. The NDA also requires contractor’s employees properly identify themselves as employees of a contractor when communicating or interacting with CDC employees, employees of other governmental entities, and members of the public (when communication or interaction relates to the contractor’s work with the CDC). The Federal Acquisition Regulation (FAR) 37.114 (c), states “All contractor personnel attending meetings, answering Government telephones, and working in other situations where their contractor status is not obvious to third parties are required to identify themselves as such to avoid creating an impression in the minds of members of the public or Congress that they are Government officials, unless, in the judgment of the agency, no harm can come from failing to identify themselves. They must also ensure that all documents or reports produced by contractors are suitably marked as contractor products or that contractor participation is appropriately disclosed.”

(c) The contractor shall inform contractor employees of the identification requirements by which they must abide and monitor employee compliance with the identification requirements.

(d) During the contract performance period, the contractor is responsible to ensure that all additional or replacement contractors’ employees sign an NDA, and it is submitted to the Contracting Officer prior to commencement of their work with the CDC.

(e) Contractor employees in designated positions or functions that have not signed the appropriate NDA shall not have access to any non-public, procurement sensitive information or participate in government meetings where sensitive information may be discussed.

(f) The Contractor shall prepare and maintain a current list of employees working under NDAs and submit to the Contracting Officer upon request during the contract period of performance. The list should at a minimum include: contract number, employee's name, position, date of hire and NDA requirement.

EXHIBIT I
Centers for Disease Control and Prevention (CDC)
Contractor Non-Disclosure Agreement

I. Non-public Information

[Name of contractor] understands that in order to fulfill the responsibilities pursuant to [contract name and number] between the Centers for Disease Control and Prevention and [Name of CDC contractor] dated [date], employees of [contractor] will have access to non-public information, including confidential and privileged information contained in government-owned information technology systems. For purposes of this agreement, confidential information means government information that is not or will not be generally available to the public. Privileged information means information which cannot be disclosed without the prior written consent of the CDC.

In order to properly safeguard non-public information, [contractor] agrees to ensure that prior to being granted access to government information or the commencement of work for the CDC, whichever is applicable, all contractor employees will sign a Non-Disclosure Agreement (NDA) provided by the CDC prior to beginning work for the CDC. Contractor agrees to submit to the Contracting Officer the original signed copies of NDAs signed by the contractor's employees in accordance with the instructions provided by the Contracting Officer. Failure to provide signed NDAs in accordance with this agreement and instructions provided by the Contracting Officer could delay or prevent the employee from commencing or continuing work at the CDC until such agreement is signed and returned to the Contracting Officer.

Contractor further agrees that it will not cause or encourage any employee to disclose, publish, divulge, release, or make known in any manner or to any extent, to any individual other than an authorized Government employee any non-public information that the employee may obtain in connection with the performance of the employee's responsibilities to the CDC.

II. Procurement-Sensitive Information
Contractor further agrees that it will not cause or encourage any employee to disclose, publish, divulge, release, or make known in any manner or to any extent, to any individual, other than an authorized Government employee, any procurement-sensitive information gained while in connection with fulfilling the employee's responsibilities at the CDC. For purposes of this agreement, procurement-sensitive information includes, but is not limited to, all information in Statements of Work (SOW), Procurement Requests (PR), and Requests for Proposal (RFP); Responses to RFPs, including proposals, questions from potential offerors; non-public information regarding procurements; all documents, conversations, discussions, data, correspondence, electronic mail (e-mail), presentations, or any other written or verbal communications relating to, concerning, or affecting proposed or pending solicitations or awards; procurement data; contract information plans; strategies; source selection information and documentation; offerors' identities; technical and cost data; the identity of government personnel involved in the solicitation; the schedule of key technical and procurement events in the award determination process; and any other information that may provide an unfair competitive advantage to a contractor or potential contractor if improperly disclosed to them, or any of their employees.

Contractor understands and agrees that employee access to any procurement-sensitive information may create a conflict of interest which will preclude contractor from becoming a competitor for any acquisition(s) resulting from this information. Therefore, if an employee participates in any discussions relating to procurement-sensitive information, assists in developing any procurement-sensitive information, or otherwise obtains any procurement-

sensitive information while performing duties at the CDC, contractor understands and agrees that contractor may be excluded from competing for any acquisition(s) resulting from this information.

III. Identification of Non-Government Employees

Contractor understands that its employees are not agents of the Government. Therefore, unless otherwise directed in writing by the CDC, contractor agrees to assist and monitor employee compliance with the following identification procedures:

A. At the beginning of interactions with CDC employees, employees of other governmental entities, and members of the public (when such communication or interaction relates to the contractor's work with the CDC), contractors' employees will identify themselves as an employee of a contractor.
B. Contractors' employees will include the following disclosures in all written communications, including outgoing electronic mail (e-mail) messages, in connection with contractual duties to the CDC:

Employee's name
Name of contractor
Center or office affiliation
Centers for Disease Control and Prevention

C. At the beginning of telephone conversations or conference calls, contractors' employees will identify themselves as an employee of a contractor.

D. Contractors' employees should not wear any CDC logo on clothing, except for a CDC issued security badge while carrying out work for CDC or on CDC premises. The only other exception is when a CDC management official has granted permission to use the CDC logo.

E. Contractors' employees will program CDC voice mail message to identify themselves as an employee of a contractor.

I understand that federal laws including, 18 U.S.C. 641 and 18 U.S.C. 2071, provide criminal penalties for, among other things, unlawfully removing, destroying or converting to personal use, or use of another, any public records. Contractor acknowledges that contractor has read and fully understands this agreement.

Name of contractor: _____

Signature of Authorized Representative of Contractor:_____

Date:_____

Copies retained by: Contracting Officer and Contractor

EXHIBIT II

Centers for Disease Control and Prevention (CDC)
Contractors' Employee Non-Disclosure Agreement

I. Non-Public Information
I understand that in order to fulfill my responsibilities as an employee of [Name of CDC contractor], I will have access to non-public information, including confidential and privileged information contained in government-owned information technology systems. For purposes of this agreement, confidential information means government information that is not or will not be generally available to the public. Privileged information means information which cannot be disclosed without the prior written consent of the CDC.

I, [Name of Employee], agree to use non-public information only in performance of my responsibilities to the CDC. I agree further that I will not disclose, publish, divulge, release, or make known in any manner or to any extent, to any individual other than an authorized Government employee, any non-public information that I may obtain in connection with the performance of my responsibilities to the CDC.

II. Procurement-Sensitive Information

I further agree that unless I have prior written permission from the CDC, I will not disclose, publish, divulge, release, or make known in any manner or to any extent, to any individual other than an authorized Government employee, any procurement-sensitive information gained in connection with the performance of my responsibilities to the CDC. I specifically agree not to disclose any non-public, procurement-sensitive information to employees of my company or any other organization unless so authorized in writing by the CDC. For purposes of this agreement, procurement-sensitive information includes, but is not limited to, all information in Statements of Work (SOW), Procurement Requests (PR), and Requests for Proposal (RFP); Responses to RFPs, including proposals, questions from potential offerors; non-public information regarding procurements; all documents, conversations, discussions, data, correspondence, electronic mail (e-mail), presentations, or any other written or verbal communications relating to, concerning, or affecting proposed or pending solicitations or awards; procurement data; contract information plans; strategies; source selection information and documentation; offerors' identities; technical and cost data; the identity of government personnel involved in the acquisition; the schedule of key technical and procurement events in the award determination process; and any other information that may provide an unfair competitive advantage to a contractor or potential contractor if improperly disclosed to them, or any of their employees.

I understand and agree that my access to any procurement-sensitive information may create a conflict of interest which will preclude me, my current employer, or a future employer from becoming a competitor for any resulting government acquisition derived from this information. Therefore, if I participate in any discussions relating to procurement-sensitive information, assist in developing any procurement-sensitive information, or otherwise obtain any procurement-sensitive information while performing my duties at the CDC, I understand and agree that I, my current employer, and any future employer(s) may be excluded from competing for any resulting acquisitions.

III. Special Non-Disclosure Agreement for Contractors with Access to CDC Grants Management and Procurement-Related Information Technology Systems

In addition to complying with the non-disclosure requirements and safeguards stated above, I understand that my authorization to use CDC's grants management and procurement systems is strictly limited to the access and functions necessary for the performance of my responsibilities to the CDC and which have been approved in advance by the CDC. I understand that I am not authorized to enter procurement requests for any requirements pertaining to contracts or subcontracts held by me or my employer.

IV. Identification as a Non-Government Employee

I understand that as an employee of a government contractor, I represent an independent organization and I am not an agent of the Government. Therefore, I agree that unless I have prior written authorization from the CDC, I will, at the beginning of interactions with CDC employees, employees of other governmental entities, members of the public (when such communication or interaction relates to the contractor's work with the CDC), identify myself as

an employee of a contractor. I further agree to use the following identification procedures in connection with my work at the CDC:

A. I will include the following disclosures in all written communications, including outgoing electronic mail (e-mail) messages:
Employee's name
Name of contractor
Center or office affiliation
Centers for Disease Control and Prevention

B. I will identify myself as an employee of a contractor at the beginning of telephone conversations or conference calls;

C. I will not wear any CDC logo on clothing, except for a CDC issued security badge while carrying out work for CDC or on CDC premises; the only other exception is when a CDC management official has granted permission to use the CDC logo.

D. I will program my CDC voice mail message to identify myself as a contractors' employee.
I understand that federal laws including, 18 U.S.C. 641 and 18 U.S.C. 2071, provide criminal penalties for, among other things, unlawfully removing, destroying or converting to personal use, or use of another, any public records. I acknowledge that I have read and fully understand this agreement.

Name of contractor: _____

Name of Employee:_____
Signature of Employee:_____
Date:_____

Copies retained by: Contracting Officer, contractor, and Contractor Employee

(END OF CLAUSE)

CDCH.20 Non-Personal Services (Jun 2020)
(a) Personal services shall not be performed under this contract. Although the Government may provide sporadic or occasional instructions within the scope of the contract, the Contractor is responsible for control and supervision of its employees. If the Contractor (including its employees) believes any Government action or communication has been given that would create a personal services relationship between the Government and any Contractor employee, the Contractor shall promptly notify the Contracting Officer of this communication or action.

(b) The Contractor shall comply with, and ensure their employees and subcontractors comply with, CDC Policy titled Contractor Identification and Safeguarding of Non-Public Information (Policy No. CDC-IS-2006-01). No Contractor employee shall hold him or herself out to be a Government employee, agent, or representative. No Contractor employee shall state orally or in writing at any time that he or she is acting on behalf of the Government. In all communications with third parties in connection with this contract, Contractor employees shall identify themselves as Contractor employees and specify the name of the company for which they work. The Contractor is limited to performing the services identified in the contract statement of work and shall not interpret any communication with anyone as a permissible change in contract scope or as authorization to perform work not described in the contract. All contract changes will be incorporated by a modification signed by the Contracting Officer.

(c) The Contractor shall ensure that all its employees and subcontractor employees working on this contract are informed of the terms and conditions herein. The Contractor agrees that this is a non-personal services contract; and that for all the purposes of the contract, the Contractor is not, nor shall it hold itself out to be an agent or partner of, or joint venture with, the Government. The Contractor shall notify its employees that they shall neither supervise nor accept supervision from Government employees. The substance of the terms herein shall be included in all subcontracts at any tier.
(d) The terms and conditions above do not limit the Government's rights under other terms of the contract, including those related to the Government's right to inspect and accept or reject the services performed under this contract.

CDCH.23 Evaluation of Contractor Performance Utilizing CPARS (Aug 2021)
In accordance with FAR 42.15, Centers for Disease Control and Prevention (CDC) will review and evaluate contract performance. FAR 42.1502 and 42.1503 requires agencies to prepare evaluations of contractor performance and submit them to the Contractor Performance Assessment Reporting System (CPARS). CDC utilizes this web-based system to prepare and report contractor performance evaluations. All information contained in these assessments may be used by the Government, within the limitations of FAR 42.15, for future source selections in accordance with FAR 15.304 where past performance is an evaluation factor.

The CPARS system requires a contractor representative to be assigned so that the contractor has appropriate input into the performance evaluation process. The CPARS contractor representative will be given access to CPARS and will be given the opportunity to concur or not-concur with performance evaluations before the evaluations are complete. The CPARS contractor representative will also have the opportunity to add comments to performance evaluations.

The assessment is not subject to the Disputes clause of the contract, nor is it subject to appeal beyond the review and comment procedures described in the guides on the CPARS website. Refer to: www.cpars.gov for details and additional information related to CPARS, CPARS user access, how contract performance assessments are conducted, and how contractors participate. Access and training for all persons responsible for the preparation and review of performance assessments is also available at the CPARS website.

The contractor must provide the CDC contracting office with the name, e-mail address, and phone number of their designated CPARS representative who will be responsible for logging into CPARS and reviewing and commenting on performance evaluations. The contractor must maintain a current representative to serve as the contractor representative in CPARS. It is the contractor’s responsibility to notify the CDC contracting office, in writing (letter or email), when their CPARS representative information needs to be changed or updated. Failure to maintain current CPARS contractor representative information will result in the loss of an opportunity to review and comment on performance evaluations.

CDCA_H037 Observance of Legal Holidays and Administrative Leave (Government Facilities Performance) (Jul 2021)
(a) Holidays

Government personnel observe the following listed days as holidays:
Washington's Birthday
Memorial Day
Juneteenth
Independence Day
Labor Day
Veterans' Day
Thanksgiving Day
Christmas Day
New Year's Day
Columbus Day
Martin Luther King Day

Any other day designated by Federal Statute

Any other day designated by Executive Order

Any other day designated by Presidential proclamation

For purposes of contract performance, the Contractor shall observe the above holidays on the date observed by the Government. Observance of such days shall not be cause for an additional period of performance or entitlement to compensation except as otherwise set forth in the contract. No form of holiday or other premium compensation will be reimbursed; however this does not preclude reimbursement for overtime work authorized in writing by the Contracting Officer.

(b) Unscheduled Facility Closures

In the event Government facilities are closed due to inclement weather, potentially hazardous or unsafe conditions, or other special circumstances, contractor personnel assigned to work within those facilities are automatically dismissed. Notwithstanding the terms herein, the contractor shall comply with any specific contract terms that require a level of ongoing support for critical operations during times of facility closure. The contractor may also continue to provide support under a scheduled telework arrangement in accordance with the terms of the contract if the contract expressly authorizes telework in writing.

(c) Cost Impact
Accounting for costs associated with an unscheduled facility closure is unique to each contract and depends upon a number of factors such as:

i) Contract type, e.g. Fixed Price, Time and Materials, or Cost Reimbursement.
ii) Contractor's established management and accounting practices for unproductive time.
iii) The inclusion and applicability of other contract terms & conditions.
iv) The ability of the contractor to mitigate costs by reassigning employees to work on other contracts, to work from a different facility, or to work remotely from home in accordance with contract telework provisions.

SECTION E - SOLICITATION PROVISIONS

HHSAR 352.239-72 Information System Security Plan and Accreditation (FEB 2024) (DEVIATION)

All offers submitted in response to this solicitation or request for quotation shall address the approach for completing the security plan and accreditation requirements in clause 352.239-71, Security Requirements for Information Technology Resources.

(End of provision)

HHSAR 352.239-78 Information and Communication Technology Accessibility Notice.)(FEB 2024) (DEVIATION)

(a) Any offeror responding to this solicitation must comply with established HHS Information and Communication Technology (ICT) accessibility standards. Information about Section 508 is available at https://www.hhs.gov/web/section-508/index.html.

(b) The Section 508 accessibility standards applicable to this solicitation are stated in the clause at 352.239-79 Information and Communication Technology Accessibility. In order to facilitate the Government's determination whether proposed ICT supplies, products, platforms, information, and documentation meet applicable Section 508 accessibility standards, offerors must submit an appropriate HHS Section 508 Accessibility Conformance Checklist (see https://www.hhs.gov/web/section-508/accessibility-checklists/index.html) or an Accessibility Conformance Report (ACR) (based on the Voluntary Product Accessibility Template (VPAT) see https://www.itic.org/policy/accessibility/vpat), in accordance with the completion instructions. The purpose of the checklists and conformance reports are to assist HHS acquisition and program officials in determining whether proposed ICT supplies, products, platforms, information, and documentation conform to applicable Section 508 accessibility standards. Checklists and ACRs evaluate—in detail—whether the ICT conforms to specific Section 508 accessibility standards and identifies remediation efforts needed to address conformance issues.

(c) If an offeror claims its supplies or services meet applicable Section 508 accessibility standards, and it is later determined by the Government, i.e., after award of a contract or order, that supplies, products, platforms, information, documentation, or services support delivered do not conform to the described accessibility standards, remediation of the supplies, products, platforms, information, documentation, or services support to the level of conformance specified in the contract will be the responsibility of the Contractor at its expense.

(d) In order to facilitate the Government's determination whether proposed ICT supplies meet applicable Section 508 accessibility standards, offerors must submit an Accessibility Conformance Report, in accordance with its completion instructions and tailored to the requirements in the solicitation. The purpose of the Report is to assist HHS acquisition and program officials in determining whether proposed ICT supplies conform to applicable Section 508 accessibility standards. The template allows offerors or developers to self-evaluate their supplies and document, in detail, whether they conform to a specific Section 508 accessibility standard, and any underway remediation efforts addressing conformance issues. Instructions for preparing the HHS Section 508 Evaluation Template are available at https://Section508.gov/.

(e) In order to facilitate the Government's determination whether proposed ICT services meet applicable Section 508 accessibility standards, offerors must provide enough information to assist the Government in determining that the ICT services conform to Section 508 accessibility standards, including any underway remediation efforts addressing conformance issues.

(f) Respondents to this solicitation must identify any inability to conform to Section 508 requirements. If an offeror claims its supplies or services meet applicable Section 508 accessibility standards, and it is later determined by the Government, i.e., after award of a contract or order, that supplies or services delivered do not conform to the described accessibility standards, remediation of the supplies or services to the level of conformance specified in the contract will be the responsibility of the Contractor at its expense.

(g) Items delivered as electronic content must be accessible to HHS acceptance criteria. Checklist for various formats are available at http://508.hhs.gov/. Materials, other than items incidental to contract management, that are final items for delivery should be accompanied by the appropriate checklist, except upon approval of the Contracting Officer or Contracting Officer’s Representative.

(End of provision)

TASK ORDER INFORMATION:

It is the Government intent to as award a firm-fixed price 8(a) service contract to be performed, with one base year and 3 option years, under 52.217-9, with the option to extend the contract term under 52.217-8 Option to Extend Services.

All contractors responding to the notice are afforded a fair opportunity to submit an offer and have the offer fairly considered.

It is in the offerors’ best interest so ensure all submittals are presented in a clear and concise manner.

52.212-1 Instructions to Offerors—Commercial Products and Commercial Services. (NOV 2025)(DEVIATION)

Instructions to Offerors—Commercial Products and Commercial Services (Deviation Date)

(a) *Submission of offers*. Submit signed and dated offers to the office specified in this solicitation at or before the exact time specified in this solicitation. As a minimum, offers shall include—

(1) The solicitation number;

(2) The name, address, telephone number of the Offeror;

(3) The Offeror’s Unique Entity Identifier (UEI) and, if applicable, Electronic Funds Transfer (EFT) indicator;

(4) Information necessary to evaluate the factors contained in the provision at 52.212-2 or as described in the solicitation;

(5) Responses to provisions that require Offeror completion of information, representations, and certifications (other than those collected via the System for Award Management (SAM)); and

(6) A statement specifying the extent of agreement with all terms, conditions, and provisions included in the solicitation and any solicitation amendments.

(b) *Period for acceptance of offers*. The Offeror agrees to hold the prices in its offer firm for 60 calendar days from the date specified for receipt of offers, unless another time period is specified in an addendum to the solicitation.

(c) *Late submissions, modifications, revisions, and withdrawals of offers*.

(1) Offerors are responsible for submitting offers and any modifications or revisions to the Government office designated in the solicitation by the time specified in the solicitation.

(2) Any offer, modification, or revision received after the time specified for receipt of offers is “late” and will not be considered unless it is received before award is made and the Contracting Officer determines that accepting the late offer would not unduly delay the acquisition. However, a late modification of an otherwise successful offer that makes its terms more favorable to the Government will be considered at any time it is received and may be accepted.

(3) If an emergency or unanticipated event interrupts normal Government processes so that offers cannot be received at the Government office designated for receipt of offers by the exact time specified in the solicitation, and urgent Government requirements preclude amendment of the solicitation or other notice of an extension of the closing date, the time specified for receipt of offers will be deemed to be extended to the same time of day specified in the solicitation on the first work day on which normal Government processes resume.

(4) Offerors may withdraw their offers by written notice to the Government received at any time before award.

(d) *Contract award (not applicable to Invitation for Bids)*. The Government intends to evaluate offers and award a contract without exchanges with Offerors. Therefore, the Offeror’s initial offer should contain the Offeror’s best terms. However, the Government reserves the right to conduct exchanges, if necessary. The Government may reject any or all offers if such action is in the public interest, accept other than the lowest offer, and waive informalities and minor irregularities in offers received.

(e) *Debriefings*. If a post award debriefing is given to requesting Offerors, the Government will disclose the following information, if applicable:

(1) The agency’s evaluation of the significant weak or deficient factors in the debriefed Offeror’s offer.

(2) The overall evaluated cost or price and technical rating of the successful Offeror and the debriefed Offeror and past performance information on the debriefed Offeror.

(3) The overall ranking of all Offerors when any ranking was developed by the agency during source selection.

(4) A summary of the rationale for award.

(5) For acquisitions of commercial products, the make and model of the product to be delivered by the successful Offeror.

(6) Reasonable responses to relevant questions posed by the debriefed Offeror as to whether the agency followed source-selection procedures set forth in the solicitation, applicable regulations, and other applicable authorities.

(End of provision)

Addenda to 52.212-1 Instructions to Offerors—Commercial Products and Commercial Services

Questions and Point of Contact Information

Questions regarding this RFP must be submitted in writing and e-mailed to the following Contract Specialist no later than 2:00 PM EST on Thursday, March 27, 2026. **Question window is closed**.

Name: Debra A. Baker

Email: xvv9@cdc.gov

Questions shall identify the pertinent RFP Section (e.g. PWS, Evaluation Procedures, RFP Preparation Instructions etc.), page number and paragraph number.

To ensure a prompt response, include: "RFP 75D301-26-Q-78990" Questions" in the subject line of the email. **NO LONGER OPEN**

Proposal Due Date

Proposals are due no later than 12:00 PM EDT on Thursday, April 9, 2026. Proposals shall be submitted electronically via email to the following Contract Specialist.

Name: Debra A. Baker

Email: xvv9@cdc.gov

Include: "RFP 75D301-26-Q-78990" in the subject line of the email.

Efficient Evaluation of Proposals

Due to the high number of offerors under the GSA STARS III GWAC, the Government reserves the right to limit the number of proposals evaluated for the purpose of efficiency. Therefore, after an initial review, the Government will only evaluate those offers determined to be among the most highly rated based on the offerors' technical capability.

If any price is found within Volume I this may be grounds for removal from the competition

INSTRUCTIONS FOR CONTRACT TECHNICAL PROPOSAL: Page Limit: 12 pages

Contract Proposal Cover Sheet. The cover sheet of the Offeror's Business Proposal should contain the following information (as applicable):

a) Solicitation or modification/amendment number;

b) Name and address of Offeror;

c) Name and telephone number of point of contact;

d) Date of submission

e) Unique Entity ID

e) Name, title, and signature of authorized representative.

Proposal Format: Pages shall be 8 ½ x 11, Times New Roman font, 12 pt. pitch, page count (stipulated above includes cover letter, table of contents, appendices, attachments, and all other documents. (Resumes or CVs and cover/title page do not count towards the page limit.) Text included in any graphics or diagrams may be no less than 10 pt. pitch. All electronic files shall be in PDF or MS Word ".doc" or ".xls" format as applicable (unprotected). It is the offerors' decision on how the 12 pages or applied.

Resumes are limited to 2 pages (Front and Back pages are counted as 2 Pages).

Any resume submittals are not included in the 12 page limit.

Any formulas used in deriving cost/price quote shall be visible when cursor is positioned in cell (i.e. do not convert formulas to values)

It is the governement's intent to award a firm fixed price contract.

The contractors' technical capabilities and past performance are as equally important as price. ***The contract will be awarded to the offeror that offers the overall best value to the government in technical capabilities and price.***

52.212-2 Evaluation—Commercial Products and Commercial Services. (NOV 2025) (DEVIATION)

(a) Evaluation factors. The Government will award a contract resulting from this solicitation to the responsible Offeror whose offer conforming to the solicitation will be most advantageous to the Government, price and other factors considered. The following factors will be used to evaluate offers:

Evaluation factors other than price when combined are approximately equal to price.

(b) *Options*. The Government will evaluate offers for award purposes by adding the total price for all options to the total price for the basic requirement. The Government may determine that an offer is unacceptable if the option prices are significantly unbalanced. The evaluation of options does not obligate the Government to exercise the option(s).

(c) *Notice of award*. A written notice of award or acceptance of an offer furnished to the successful Offeror within the time for acceptance specified in the offer, shall result in a binding contract without further action by either party. Before the offer's specified expiration time, the Government may accept an offer (or part of an offer), whether or not there are negotiations after its receipt, unless a written notice of withdrawal is received before award.

(End of provision)

Addenda to FAR 52. 212-2 Evaluation—Commercial Products and Commercial Services

Technical Evaluation Factors (listed in descending order of importance):

1. *Technical Approach*: The Offeror shall provide an analysis of the task requirements to indicate their understanding of the task requirements, operating environment, and the Contract objectives. The Offeror shall provide a description of the performance techniques and methodology they propose in performance of this task.

The Offeror shall specifically address aspects such as technical understanding, methodology and approach, along with the sub-factors listed below.

a. Provide a detailed and comprehensive statement of the problem, scope, and purpose of the project to demonstrate complete understanding of the intent and requirements of the contract and potential problems that may be encountered.

b. Describe the proposed technical approach to comply with each of the requirements specified in the Statement of Work (PWS). The proposal must be consistent with the stated goals and objectives. The proposed approach must ensure the achievement of timely and acceptable performance and will include a milestone and/or phasing charts to illustrate a logical sequence of proposed events.

c. Discuss the plan and solutions for overcoming difficulties involved with performing the work requirements.

2. Management and Staffing Plan: The Offeror shall demonstrate an overall understanding of the project and adequacy and feasibility of plans to address all items in the Statement of Work (PWS). This includes:

   a. A detailed description of how conflicts are managed;

   b. A description explaining how they will build a relationship with subcontractors; and

   c. A detailed statement of staffing and recruitment proposed for this Contract. This element may be demonstrated through personnel resumes.

3. Similar Experience: The Offeror shall provide a one page description of three contracts or Contracts completed within the past three years that clearly demonstrate the Offeror's experience in performing projects of similar scope, size and complexity to the requirements described in the RFP. The following information shall be provided for each project reference:

   a. Contract number, customer/agency name and contract title;

b. Dollar value, contract type, period of performance, place of performance, and the number and types of personnel used in the performance of the contract; and

c. Brief narrative description of the work performed for each of those contracts, including a discussion of any problems encountered/corrective actions and significant accomplishments; and

d. Name, address, and phone number of at least two (2) customer contacts (Contracting Officer and Project Officer or Contracting Officer's Representative, or Commercial point of contact if applicable) for each of the identified contracts.

INSTRUCTIONS FOR PREPARING THE PRICE PROPOSAL

No Page Limit

The price proposal shall be comprised of the following elements:

(a) A completed copy of **Section B-Supplies or Services and Prices/Costs**.

(b) The proposed labor categories, estimated labor hours, and rates.

Sample table is provided as follows:

Labor Category	Rate	Discounted Rate (if applicable)	Hours	Total Amount

(c) Any other non-labor costs (materials, supplies, travel, sub-contracts, consultants, etc.) if applicable, shall be provided with supporting documentation.

This price/cost data will be used to establish the reasonableness of the proposed price. Discounts are acceptable.

(d)The proposed payment schedule for the awarded Contract.

Labor Categories

Offerors are advised to conduct their own analysis of the requirements and propose their best solution based upon their independent assessments. However, the Government estimates that the rates of this requirement can be fulfilled utilizing a total annual range of hours as reflected below:

Labor Category	Estimated Hours (Annually)
SharePoint/Application Developer	1920

Award shall be made on a pass/fail basis. The offeror must receive a rating of "pass" on each of the following technical evaluation criteria:

A. Technical Approach

B. Management Plan and Staffing Plan

C. Similar Experience

Notice of Intent to Award Without Discussions

The Government intends to evaluate proposals and award the Contract without discussions with the offerors. Therefore, the offeror's initial proposal should contain the offeror's best terms from a cost or price and technical standpoint. However, the Government reserves the right to conduct discussions if the Contracting Officer later determines them to be necessary.

EVALUATION OF OPTIONS

Options. Except when it is determined not to be in the Government's best interest, the Government will evaluate offers for award purposes by adding the total price for all options to the total price for the basic requirement. The Government may determine that an offer is unacceptable if the option prices are significantly unbalanced. Evaluation of options shall not obligate the Government to exercise the option(s).

Factor 1—Technical Capabilities

Evaluation of Technical Proposal

Sub-Factor 1: Technical Approach:

This criterion will be evaluated according to the extent that the Offeror's discussion of their technical approach for providing the services required for this Contract reflects a clear understanding of the subject areas to be accomplished and on the soundness, practicality, and feasibility of the contractor's technical approach for providing the services required for this Contract.

Sub-Factor 2: Management and Staffing Plan:

This criterion will be evaluated according to the soundness, practicality, and feasibility of the contractor's management and staffing plan for this Contract. Personnel assigned to the Contract should have relevant experience and expertise.

Sub-Factor 3: Similar Experience:

This criterion will be evaluated using information reflecting the contractor's organizational capacity for projects similar in complexity and scope to determine appropriate experience of assigned personnel and of the company.

Technical and/or Subfactor Rating Definitions

Technical: The Government will conduct a technical evaluation for the proposal. The evaluation will be conducted using the subfactors identified in the table below. The number adjacent to each subfactor in the table below indicates the importance in descending order of importance.

Subfactor #	Subfactor Description
1	Technical Approach
2	Management and Staffing Plan
3	Similar Experience

The Government may consider the order of importance of each subfactor when considering best value. Thus the purpose of order importance with the subfactors is to maximize the Government's best value determination.

Factor 2 – Cost/Price

The Government will evaluate the offeror's cost/price in relation to the offeror's proposed technical approach to validate that the proposed cost/price is commensurate with the proposed technical approach. A detailed cost breakdown should be provided.

Factor 3 – Past Performance

By past performance, the Government means the Offerors record of conforming to specifications and to standards of good service; adherence to contract schedules including the administrative aspects of performance; reputation for reasonable and cooperative behavior and commitment to customer satisfaction; and generally business-like concern for the interest of the customer. Evaluation of past performance will be based on performance documentation or any other pertinent information available to the Government. The Government reserves the right to consider the Offerors past performance from other available sources, such as data gathered through CPARS/PPIRS or SAM.gov for data about the offeror's past performance, the offeror's proposed employees, and subcontractors. CDC is seeking to determine whether an Offeror has consistently demonstrated a strong commitment to customer satisfaction and high performance of services. Failure to provide available information to assist in such evaluation in the proposal may result in exclusion from award. The Government will assess if the offeror is responsible and the relative risks of performance. Performance risks are those associated with an Offerors likelihood of success in performing the contract requirements as indicated by that Offerors record of current and past performance.